WSQ
Singapore Workforce Skills Qualifications
Funded by SkillsFuture Singapore

AI SECURITY GOVERNANCE FOR BUSINESSES
WSQ · TGS-2026061329

COURSE SLIDES · WSQ

AI Security Governance for Businesses

WSQ Course Code: TGS-2026061329

Conducted by Tertiary Infotech Academy Pte Ltd · UEN 201200696W

Version v1.0 · 1 September 2026

© 2026 Tertiary Infotech Academy Pte Ltd. All rights reserved. · www.tertiarycourses.com.sg

COURSE ADMINISTRATION

Welcome & Housekeeping

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

1

Three times a day

Take the AM, PM and Assessment digital attendance — mandatory for every WSQ-funded course.

2

Trainer shows the QR

The trainer or administrator displays the digital attendance QR code from the SSG portal.

3

Scan and submit

Scan the QR code with your mobile phone camera and submit your attendance.

4

75% minimum

A minimum of 75% attendance is required to be eligible for assessment and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

About the Trainer



Your Trainer

General Trainer template —
to be completed by the trainer

NAME

TITLE / DESIGNATION

QUALIFICATIONS

AREAS OF EXPERTISE

TRAINING & INDUSTRY EXPERIENCE

CONTACT

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR TRAINER

About the Trainer



Dr Alfred Ang

Principal Trainer
Tertiary Infotech Academy Pte Ltd

ROLE

Principal Trainer, Tertiary Infotech Academy Pte Ltd

EXPERTISE

AI governance and security, responsible AI, cybersecurity risk management and applied machine learning.

DELIVERS

WSQ courses on AI security governance, responsible AI, data protection and generative AI for business.

CREDENTIALS

PhD; ACTA/ACLP certified; certified in AI Ethics & Governance, Explainable AI and Safeguarding AI.

© 2026 Tertiary Infotech Academy Pte Ltd

ICE-BREAKER

Let's Know Each Other

- Your name, organisation and role.
- Does your organisation use AI today — and does anyone govern it?
- What worries you most about AI in your business: data leakage, wrong decisions, regulators, or something else?
- What you would like to be able to do differently after these two days.

© 2026 Tertiary Infotech Academy Pte Ltd

HOUSEKEEPING

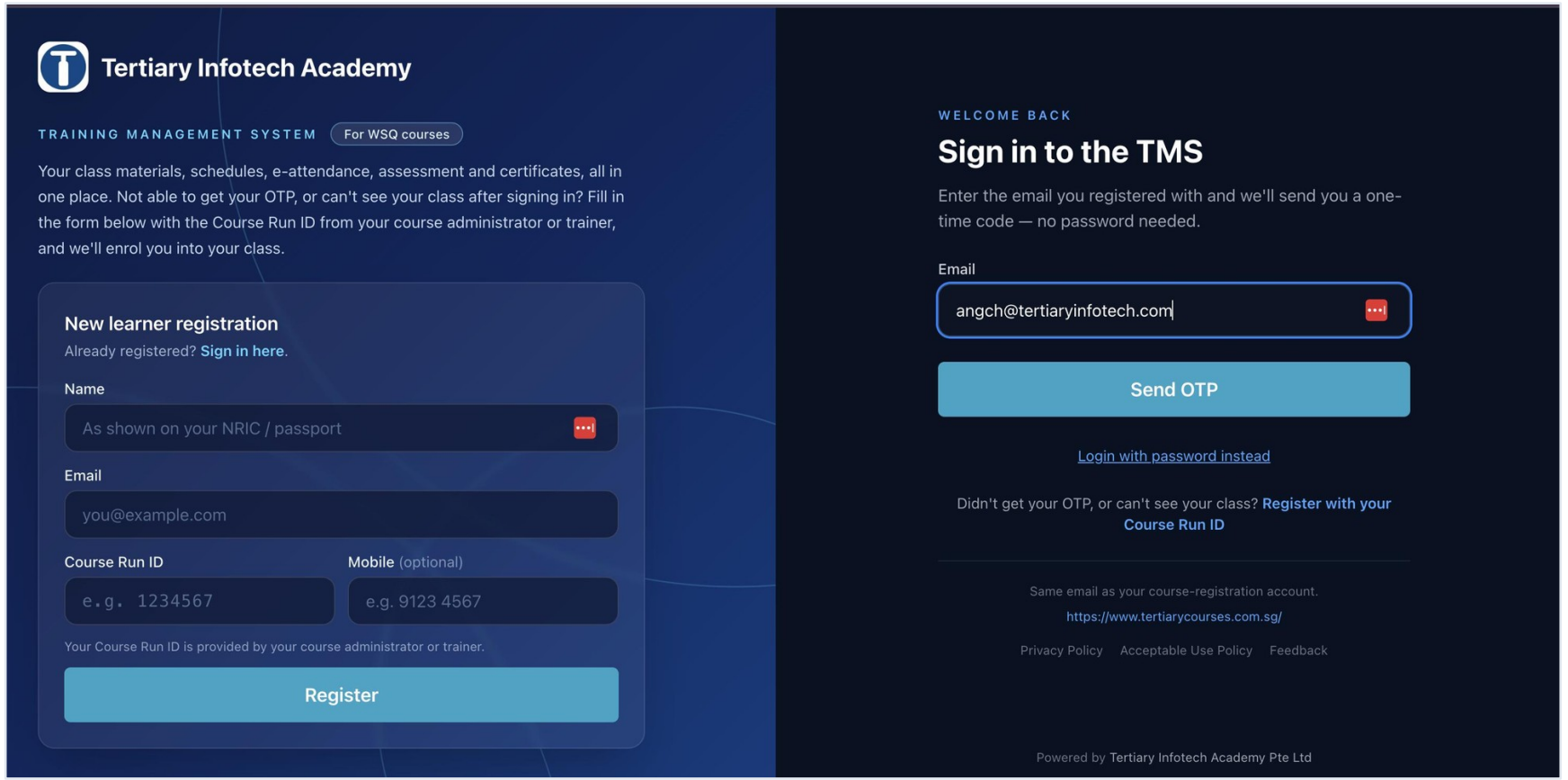
Ground Rules

1. Set your mobile phone to silent mode.
2. Participate actively — no question is too small.
3. Mutual respect: agree to disagree.
4. One conversation at a time.
5. Be punctual; return from breaks on time.
6. 75% attendance is required.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL

Login to LMS and Download Course Material



Log in at lms-tms.tertiaryinfotech.com with your registered email and the OTP sent to your inbox, then open this course to download the slides and Learner Guide.

© 2026 Tertiary Infotech Academy Pte Ltd

Skills Framework Alignment

1

TSC Title

Responsible AI and Generative AI Practices

2

TSC Code

ICT-INT-0055-1.1

3

Proficiency Level

Level 1

4

Knowledge

Ethical frameworks and guidelines for AI-powered tools, including legal requirements for data use.

5

Ability

Evaluate ethical frameworks and guidelines in AI development and deployment.

6

Ability

Develop and champion strategies that apply governance principles to reduce risk in deployment.

© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Lesson Plan — 2 Days, 8 hours/day

Day 1

- Day 1 — Foundations, Business Risks and Building the Governance Framework

– Digital Attendance (AM) · Introductions · Learning Outcomes

– Topic 1: Foundations and Business Risks (Labs 1–4)

– Lunch Break · Digital Attendance (PM)

– Topic 2: Building the Governance Framework (Labs 5–8)

Day 2

- Day 2 — Lifecycle Controls, Agentic AI Security and the Implementation Roadmap

– Digital Attendance (AM) · Day 1 recap

– Topic 3: Governance Controls Across the AI Lifecycle (Labs 9–12)

– Lunch Break · Digital Attendance (PM)

– Topic 4: Agentic AI Security, Risk Assessment & Roadmap (Labs 13–16)

– TRAQOM Survey · Digital Attendance (Assessment) · Final Assessment (WA + CS)

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL ACHIEVE

Learning Outcomes

1

LO1 · Analyse foundations & risks

Analyse AI security governance foundations and the business risks that AI, generative AI and agentic AI introduce.

2

LO2 · Evaluate frameworks & build structure

Evaluate AI governance frameworks and build a governance structure of policies, roles, risk ownership and accountability.

3

LO3 · Develop lifecycle controls

Develop and apply governance controls across the AI lifecycle, from data and development to deployment and decommissioning.

4

LO4 · Implement agentic controls & roadmap

Implement agentic AI security controls, run an AI risk assessment and produce a prioritised implementation roadmap.

© 2026 Tertiary Infotech Academy Pte Ltd

FOUR TOPICS · 16 HANDS-ON LABS

Course Outline

1

Topic 01 — AI Security Governance Foundations and Business Risks

Why AI changes the risk picture · the AI threat landscape · GenAI and agentic risk · the business case

2

Topic 02 — Building an AI Governance Framework: Policies, Roles and Risk Ownership

NIST AI RMF · MGF for GenAI · PDPA duties · policy architecture · roles, RACI and the AI inventory

3

Topic 03 — Governance Controls Across the AI Lifecycle

Data governance · secure development · testing and red-teaming · deployment · monitoring · incident response · decommissioning

4

Topic 04 — Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Agentic threat model · identity and least agency · guardrails and sandboxing · CSA agentic RMF profile · risk assessment · roadmap

© 2026 Tertiary Infotech Academy Pte Ltd

BEFORE YOU START

Briefing for Assessment

1

Do · Clear your desk

Place phones and other materials under the table or on the floor.

2

Don't · No recording

No photos or recording of assessment scripts.

3

Don't · No discussion

Work individually — no discussion during the assessment.

4

Do · Black or blue pen

Use a black or blue pen for hard-copy assessments.

5

Don't · No correction fluid

No liquid paper or correction tape may be used.

6

Do · Stop on time

Scripts are collected when time is up.

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Assessment

1

Written Assessment (WA)

Short-Answer Questions (SAQ) · 1 hour · open book. Tests the underpinning governance knowledge taught in the slides.

2

Case Study (CS)

One coherent governance case study · 1 hour · open book. Tests the abilities you built in the labs.

3

Open book

You may use the course slides, the Learner Guide, your lab outputs and approved materials only.

4

Eligibility

A minimum of 75% attendance is required to be eligible for assessment and funding.

5

Result

You are assessed as Competent (C) or Not Yet Competent (NYC) on each instrument.

6

Appeals

An appeal process is available if you wish to contest an assessment outcome.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1

TRAQOM survey

Scan the QR on the LMS

2

Digital attendance

Scan the SSG QR

3

Sit the WA then the CS

Open book · 1 hour each

4

Submit on the LMS

Upload your answers

5

Sign the record

Assessment Summary Record

REMEMBER

All five steps are mandatory for WSQ funding — missing the digital attendance or the TRAQOM survey can invalidate your claim.

© 2026 Tertiary Infotech Academy Pte Ltd

WSQ FUNDING

Criteria for Funding

1

Attendance

A minimum attendance rate of 75%, based on the SSG Digital Attendance record.

2

Assessment

Complete both assessment components and be assessed as 'Competent'.

3

Digital attendance

Scan the SSG QR code for AM, PM and Assessment on every training day.

4

TRAQOM survey

Complete the mandatory TRAQOM course feedback survey on the LMS.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB ENVIRONMENT · ALL BROWSER-BASED

The Lab Tools You'll Use

1

Cybersecurity Threat Simulator

alfredang.github.io/cybersecuritysimulator — ten threat modules: phishing, XSS, SQL injection, passwords, social engineering, data leakage.

2

Hacklab — Ethical Hacking Simulator

alfredang.github.io/ethnicalhacking — eleven scripted labs across recon, scanning, enumeration and forensics, in a safe simulated terminal.

3

FauxBank — Pentest Sandbox

pentest-fauxbank.vercel.app — a fictional bank for guided pentest, a simulated scanner and report generation.

4

Cryptography Toolkit

alfredang.github.io/cryptography-toolkit — AES, RSA and ECDSA for the data-protection lab.

5

All browser-based

Zero install, no real network traffic, fictional data only — safe to run on the training network.

6

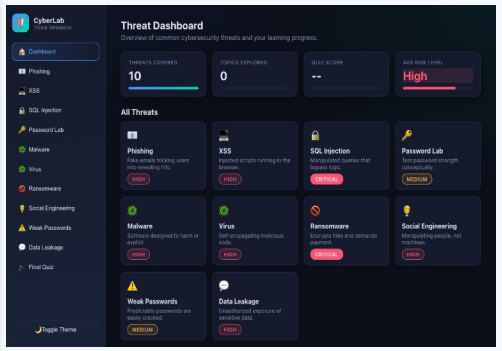
Never against real systems

These techniques are for authorised testing only. Never apply them to a system you do not have written authorisation to test.

© 2026 Tertiary Infotech Academy Pte Ltd

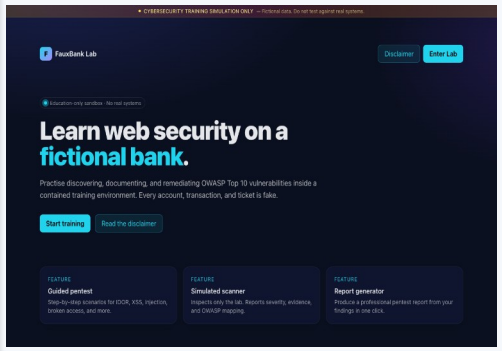
ALL BROWSER-BASED · FICTIONAL DATA ONLY

The Lab Tools — What You'll See



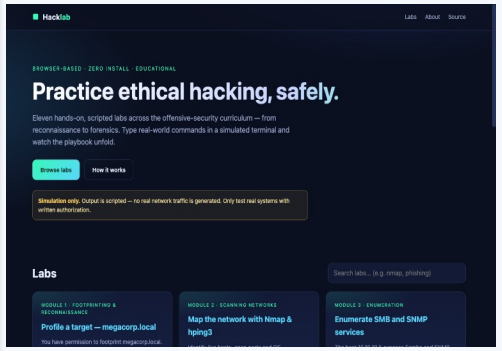
Cybersecurity Threat Simulator

Ten threat modules: phishing, SQL injection, XSS, passwords, social engineering and data leakage. Used in Lab 2 (mapping the AI threat landscape).



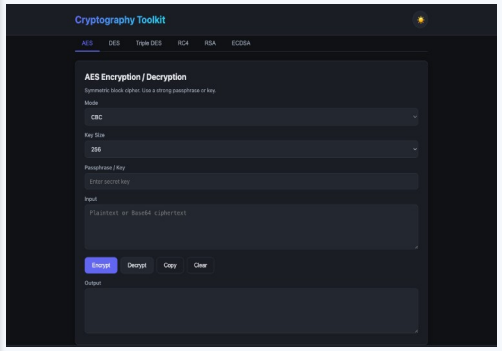
FauxBank Pentest Sandbox

A fictional bank for guided pentest — IDOR, injection and broken access control — with a simulated scanner and report generation. Used in Lab 10 (pre-deployment red team).



Hacklab Ethical Hacking Simulator

Eleven scripted labs across recon, scanning, enumeration and forensics in a safe simulated terminal. Used in Lab 10 (reconnaissance stage).



Cryptography Toolkit

AES, RSA and ECDSA — encryption, key generation and digital signatures. Used in Lab 9 (governing the training data).

No installation and no real network traffic. These techniques are for authorised testing only — never apply them to a system you do not have written authorisation to test.

© 2026 Tertiary Infotech Academy Pte Ltd

CASE STUDY · NOVABANK

The Running Case Study — NovaBank

1

One organisation, sixteen labs

Every lab builds on the last for the same fictional Singapore retail bank, so your outputs compose into one governance programme.

2

Day 1 · Discover and frame

You inventory the AI estate, map the threats, analyse an agent design and build the business case.

3

Day 1 · Build the framework

You run a NIST gap assessment, draft the policy set, design the operating model and apply the PDPA.

4

Day 2 · Control the lifecycle

You govern the data, red-team the system, design deployment gates and monitoring, and run an incident.

5

Day 2 · Secure the agents

You design the agentic control stack, apply the CSA agentic profile, assess risk and build the roadmap.

6

You leave with artefacts

An inventory, a policy set, a RACI, a risk assessment and a 12-month roadmap you can adapt to your own organisation.

© 2026 Tertiary Infotech Academy Pte Ltd

CORE CONCEPTS

Why AI Changes the Security and Governance Picture

© 2026 Tertiary Infotech Academy Pte Ltd

THE SHIFT

Security governance asks 'is the system protected?'

AI security governance also asks: where did the data come from, what did the model learn, who decided, can we explain it — and what is the agent allowed to do on its own?

© 2026 Tertiary Infotech Academy Pte Ltd

LO1 · DEFINITION

What Is AI Security Governance?

1

A system, not a document

The policies, roles, controls and evidence that keep AI systems secure, lawful and accountable across their whole life.

2

Built on what you have

It extends information-security and data-protection governance — it does not replace them, and building it in parallel is a known failure mode.

3

Three questions it must answer

What AI do we run? Who is accountable for each system? What happens when one of them behaves badly?

4

Evidence is the output

Governance that cannot produce evidence to a regulator, an auditor or a customer is not governance — it is intention.

© 2026 Tertiary Infotech Academy Pte Ltd

Traditional IT Governance vs AI Security Governance

Dimension	Traditional IT system	AI system
Behaviour	Deterministic — same input, same output	Probabilistic — the same input can produce different output
Attack surface	Code, config, infrastructure, credentials	Plus training data, model, prompts, context and tools
Change control	Releases go through CAB	Model, prompt and retrieval changes often bypass CAB entirely
Failure mode	It crashes or returns an error	It answers confidently and incorrectly
Explainability	Read the code	May require dedicated explainability technique
Testing	Does it meet the spec?	Plus: is it fair, robust, private, and jailbreak-resistant?
Autonomy	None — it does what it is told	An agent decides what to do next, and acts

WHEN IT MATTERS Every row on the right is a control gap in an organisation that has only classical IT governance — which is most organisations.

© 2026 Tertiary Infotech Academy Pte Ltd

The Five New Assets You Must Protect

1

1 · Training and fine-tuning data

Poisoned or unlawfully sourced data becomes permanent model behaviour. Provenance matters before training, not after.

2

2 · The model itself

Weights are intellectual property and can be stolen, extracted or inverted to reveal training data.

3

3 · Prompts and context

The system prompt is a security control. Whatever enters the context window can influence behaviour.

4

4 · The inference endpoint

An unauthenticated or over-permissive endpoint is an open door with a very large blast radius.

5

5 · The tools an agent can call

This is the one most organisations miss. The agent's risk is set by what its tools can do, not by what the model says.

6

Plus the humans

Over-reliance on confident output is a control failure, not a user error — design the human check deliberately.

© 2026 Tertiary Infotech Academy Pte Ltd

Traditional Threats and Their AI-Era Variants

Traditional threat	AI-era variant	What changes
Phishing	GenAI spear-phishing and deepfakes	Volume and quality: personalised at scale, near-zero cost
SQL injection	Prompt injection	Data and instructions share one channel; no parameterisation exists
XSS	Unsafe rendering of model output	Markdown links and HTML in output can auto-fetch attacker URLs
Weak credentials	Over-scoped agent identity	One shared service account with broad read access to everything
Malware	Poisoned package or model artefact	Supply chain now includes models, embeddings and MCP servers
Insider data theft	Training-data and context leakage	The model memorises; the context window carries it out
Ransomware	Agent with write access at machine speed	No human pace limit on destructive action

WHEN IT MATTERS Your existing security knowledge transfers. What changes is the channel, the speed and the fact that the instruction and the data arrive together.

© 2026 Tertiary Infotech Academy Pte Ltd

The 12 NIST Generative AI Risks

1. **CBRN information**
   Access to materially lowered barriers for weapons-related information.
2. **Confabulation**
   Confidently stated false content — the risk most likely to reach your customers.
3. **Dangerous or violent content**
   Generation of content that recommends or facilitates harm.
4. **Data privacy**
   Leakage or inference of personal data from training data, prompts or outputs.
5. **Environmental impact**
   Energy and resource cost of training and serving at scale.
6. **Harmful bias & homogenisation**
   Discriminatory outputs; monoculture from one model used everywhere.
7. **Human-AI configuration**
   Over-reliance, poor handoff, and humans rubber-stamping model output.
8. **Information integrity**
   Synthetic content degrading trust in what is real.
9. **Information security**
   Prompt injection, model extraction, expanded attack surface.
10. **Intellectual property**
    Training on, or reproducing, protected material.
11. **Obscene or abusive content**
    Generation of non-consensual or degrading material.
12. **Value chain & components**
    Third-party models, data and packages you did not build and cannot fully inspect.

© 2026 Tertiary Infotech Academy Pte Ltd

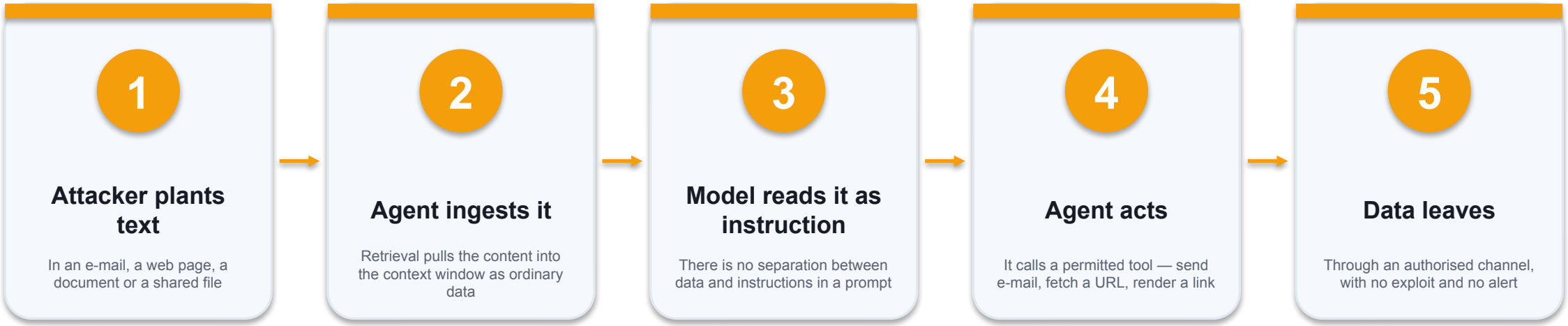
LO1 · THE PATTERN BEHIND THE 2025–26 AGENT BREACHES

The lethal trifecta

Private data access + exposure to untrusted content + the ability to communicate externally. An agent with all three can be steered by an attacker into leaking data through entirely permitted actions.

© 2026 Tertiary Infotech Academy Pte Ltd

How a Prompt-Injection Data Leak Actually Happens



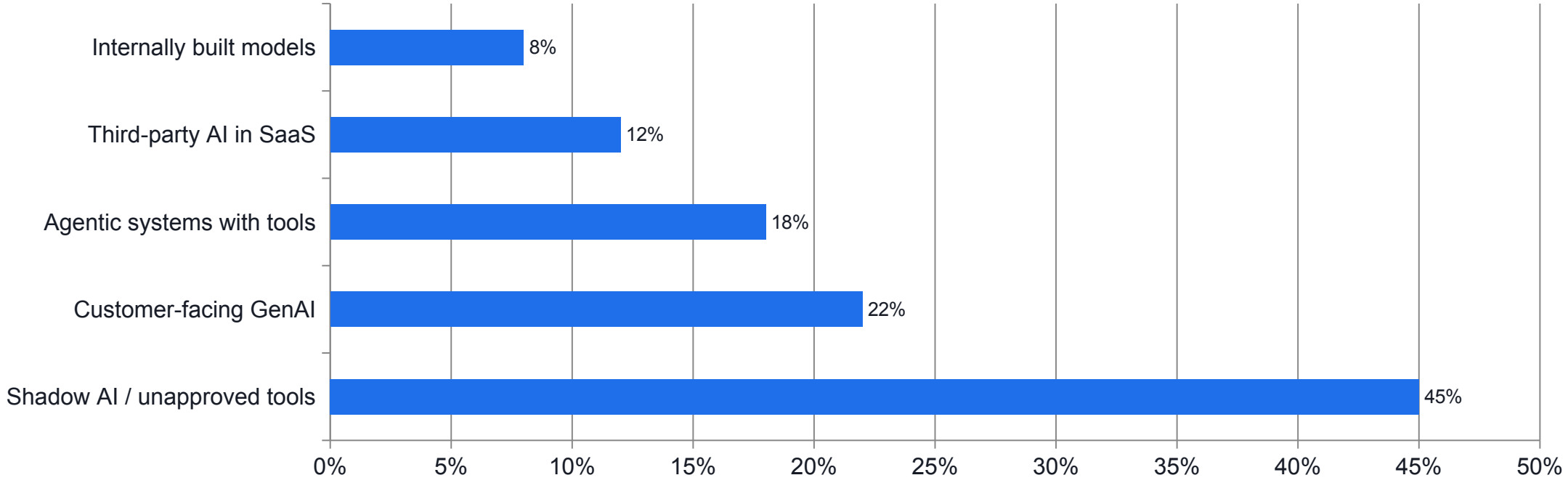
WHY FILTERS DON'T SAVE YOU

Every step uses permitted functionality. Nothing is 'hacked'. This is why the fix is architectural — break a leg of the trifecta — rather than adding another output filter.

© 2026 Tertiary Infotech Academy Pte Ltd

LO1 · WHERE TO LOOK FIRST

Where AI Risk Concentrates in a Typical Business



WHAT THE DATA SHOWS

Shadow AI dominates because it is invisible to every control you already run. Illustrative teaching figures — the pattern, not the precise number, is the point: your first control is an inventory, not a firewall.

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact — Speaking the Board's Language

1

Regulatory

PDPA enforcement, MAS supervisory action, and the cost of proving compliance you cannot currently evidence.

2

Contractual

Client contracts increasingly require AI assurance. No assurance, no renewal.

3

Intellectual property

Confidential strategy, code and customer data pasted into tools that retain and train on it.

4

Operational

An agent that acts wrongly at machine speed causes damage faster than a human can notice.

5

Decision quality

Confident, wrong output relied upon in credit, hiring or fraud decisions about real people.

6

Reputational

'Bank's AI leaked customer data' is a headline that outlives the technical fix.

© 2026 Tertiary Infotech Academy Pte Ltd

FRAMEWORKS

The Governance Frameworks You Will Apply

© 2026 Tertiary Infotech Academy Pte Ltd

LO2 · THE FRAMEWORK YOU WILL ASSESS AGAINST

NIST AI RMF 1.0 — The Four Functions



GOVERN IS NOT A STAGE

GOVERN is infused through the other three. Compliance and evaluation aspects of GOVERN should be integrated into MAP, MEASURE and MANAGE — not done once at the start.

© 2026 Tertiary Infotech Academy Pte Ltd

The Seven Characteristics of Trustworthy AI

1. **Valid and reliable**
   It does what it claims, repeatably, in the conditions it will actually meet.

2. **Safe**
   It does not create conditions endangering life, health, property or the environment.

3. **Secure and resilient**
   It withstands adversarial input and unexpected conditions, and recovers.

4. **Accountable and transparent**
   Someone is answerable, and information about the system is available to those who need it.

5. **Explainable and interpretable**
   The mechanism and the meaning of an output can be conveyed appropriately.

6. **Privacy-enhanced**
   Anonymity, confidentiality and control over personal data are safeguarded.

7. **Fair with harmful bias managed**
   Systemic, computational and human-cognitive bias are identified and managed.

8. **They trade off**
   These characteristics interact — optimising one can degrade another. Managing the trade-off is the governance work.

© 2026 Tertiary Infotech Academy Pte Ltd

LO2 · THE FUNCTION MOST ORGANISATIONS SCORE WORST ON

GOVERN — The Six Categories

1

GOVERN 1 · Policies & processes

Legal requirements understood; trustworthiness in policy; risk tolerance; AI inventory (1.6); safe decommissioning (1.7).

2

GOVERN 2 · Accountability

Roles and responsibilities documented (2.1); AI risk training (2.2); executive leadership takes responsibility (2.3).

3

GOVERN 3 · Diverse teams

Decisions informed by diverse demographics, disciplines and expertise; human-AI oversight roles defined.

4

GOVERN 4 · Risk culture

Critical thinking and safety-first mindset; teams document and communicate impacts; testing and incident sharing enabled.

5

GOVERN 5 · Stakeholder engagement

Feedback from those outside the developing team is collected, prioritised and integrated.

6

GOVERN 6 · Third-party risk

Policies address third-party AI and data risk (6.1) and contingency for third-party failures (6.2).

© 2026 Tertiary Infotech Academy Pte Ltd

Singapore's MGF for Generative AI — Nine Dimensions (K3)

1

1 · Accountability

Allocate responsibility along the AI development chain so end-users have someone answerable.

2

2 · Data

Ensure data quality and trusted sources; give clarity on contentious data — personal data and copyright.

3

3 · Trusted development & deployment

Best practice in development and evaluation, plus 'food label'-type transparency on safety measures taken.

4

4 · Incident reporting

Structures and processes for monitoring, timely notification and remediation.

5

5 · Testing & assurance

Third-party testing for independent verification, and common standards so results are comparable.

6

6 · Security

GenAI introduces new threat vectors through the models themselves; adapt existing InfoSec frameworks.

7

7 · Content provenance

Transparency about where and how content was generated — watermarking and cryptographic provenance.

8

8 · Safety & alignment R&D

Invest in alignment with human intention and values; global cooperation across AI safety institutes.

9

9 · AI for public good

Democratised access, public-sector adoption, upskilling and sustainability.

© 2026 Tertiary Infotech Academy Pte Ltd

AI Verify — Turning Claims Into Evidence (A6)

1

Singapore's testing framework

An AI governance testing framework and toolkit from IMDA and the AI Verify Foundation.

2

Test, don't assert

It lets an organisation demonstrate through standardised tests that a system behaves as claimed.

3

Serves two MGF dimensions

It produces exactly the evidence that 'trusted development and deployment' and 'testing and assurance' call for.

4

Why it matters commercially

Independent verification is becoming a procurement requirement, not a differentiator.

© 2026 Tertiary Infotech Academy Pte Ltd

The Frameworks Side by Side (A6, K3)

Framework	Origin	What it gives you	Use it for
NIST AI RMF 1.0	NIST (US), voluntary	GOVERN / MAP / MEASURE / MANAGE structure	Your gap assessment and control structure
NIST AI 600-1	NIST GenAI profile	12 named GenAI risks + suggested actions	Risk identification for generative systems
MGF for GenAI	IMDA / AI Verify (SG)	Nine dimensions of a trusted ecosystem	Aligning to Singapore expectations
AI Verify	IMDA / AI Verify (SG)	Testing framework and toolkit	Producing assurance evidence
PDPA + PDPC AI Guidelines	PDPC (SG), law + guidance	Lawful basis, notification, accountability	Anything touching personal data
CSA Agentic RMF Profile	Cloud Security Alliance	Agentic extensions: AG-GV/MP/MS/MG	Governing agents specifically
OWASP ASI Top 10	OWASP	Agentic threat taxonomy	Threat modelling an agent

WHEN IT MATTERS These are complementary, not competing. NIST gives structure, Singapore gives local expectation and law, CSA and OWASP give the agentic detail NIST does not yet cover.

© 2026 Tertiary Infotech Academy Pte Ltd

Does the PDPA Let You Use This Personal Data for AI? (K3)



YES — proceed on consent

Ensure the notification was meaningful: the individual can understand what data is used and broadly how the system uses it to decide or recommend.

NO — is an exception available?

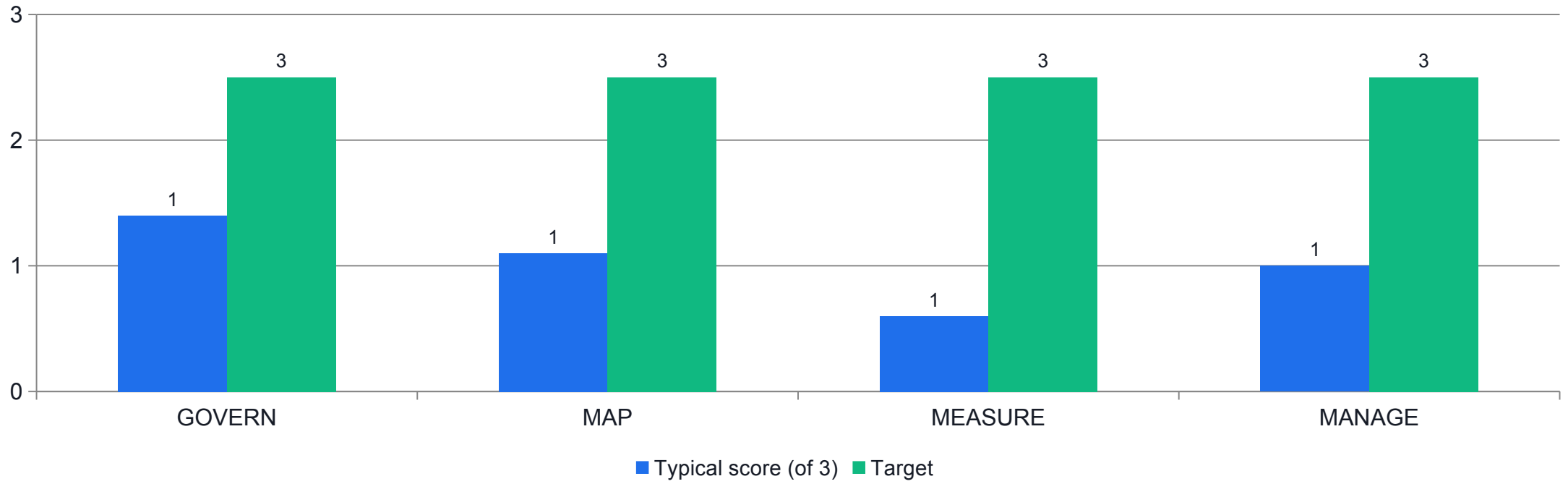
Business Improvement Exception for improving or developing an existing product or service. Research Exception for commercial research with public benefit. Record the basis in writing.

Whichever route you take, the Accountability Obligation still applies: you must be able to SHOW how you discharge your obligations — policies, the written basis, and the measures protecting individuals.

© 2026 Tertiary Infotech Academy Pte Ltd

LO2 · WHERE THE GAPS USUALLY ARE

Typical Organisational Maturity by RMF Function



WHAT THE DATA SHOWS

MEASURE scores lowest almost everywhere: organisations with mature InfoSec still rarely test AI systems for bias, robustness or jailbreak resistance. Indicative pattern for teaching — you will produce NovaBank's real scores in Lab 5.

© 2026 Tertiary Infotech Academy Pte Ltd

RESPONSIBLE AI

Ethics, Bias, Privacy and Sustainability in AI Governance

© 2026 Tertiary Infotech Academy Pte Ltd

WHY THIS SECTION

Security governance and responsible AI are the same programme.

A system can be perfectly secure and still be unfair, opaque, privacy-invasive or wasteful. The governance framework you build has to carry both — which is why this course assesses both.

© 2026 Tertiary Infotech Academy Pte Ltd

Ethical Considerations Across AI Development (K5)

1

Bias

Consider it at every stage — data provenance and representation, the fairness measure chosen at design, group-wise testing before release, and drift monitoring after it.

2

Privacy

Minimisation and purpose limitation before training; lawful basis under the PDPA; de-identification; access control; retention limits; and what happens on a deletion request.

3

Transparency

Disclose that AI is in use, what it does and its limits. Meaningful notification where personal data is used; explanation where a decision affects someone.

4

Accountability

A named human accountable for each system — NIST GOVERN 2.1 and 2.3, and the first MGF dimension. In practice: an inventory with owners and one Accountable per control.

5

They trade off

Stronger privacy usually costs accuracy; more explainability constrains model choice. Managing and RECORDING the trade-off is the governance work.

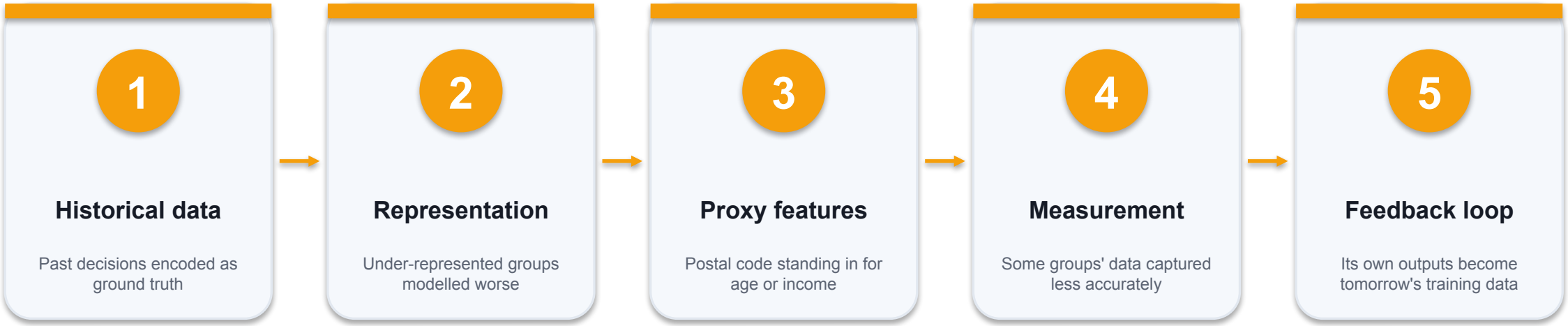
6

Proportionality

Risk-tier each system and scale assessment, testing and oversight to the tier, so effort follows risk and the process survives contact with the business.

© 2026 Tertiary Infotech Academy Pte Ltd

How Bias Enters an AI System (K2, A4)



THE POINT

Bias is rarely a biased developer. It is ordinary data and ordinary design choices reproducing an existing pattern — which is why it must be TESTED for, not assumed absent.

© 2026 Tertiary Infotech Academy Pte Ltd

Implications of Biased AI Algorithms (K2, A8)

1

On the individual

A concrete unfair outcome — a delayed appointment, a declined loan, a screened-out application — usually falling on the person least able to challenge it.

2

On groups and cultures

One model decides every case identically, so an error is applied SYSTEMATICALLY to a whole group rather than randomly. Scale turns small bias into population-level harm.

3

On minority groups

Smaller groups are under-represented in training data, so error rates are higher exactly where the ability to contest a decision is often lowest.

4

On language and culture

Systems perform best in the language and cultural context they were trained on — a live concern in multilingual Singapore.

5

On the organisation

Regulatory exposure, contractual and legal risk, loss of trust, and remediation cost far above the cost of testing beforehand.

6

Compounding

Feedback loops and algorithmic monoculture — many organisations using the same model — entrench the same bias across a whole market.

© 2026 Tertiary Infotech Academy Pte Ltd

Fairness Is Not One Thing — Choose the Measure (A4)

Fairness measure	What it requires	Use it when	The catch
Demographic parity	Equal positive rates across groups	Outreach, access to opportunity	Ignores genuine differences in need
Equal opportunity	Equal true-positive rates across groups	Screening where a miss is the harm	Needs reliable ground-truth labels
Equalised odds	Equal true- AND false-positive rates	High-stakes decisions about people	The hardest to satisfy in practice
Calibration	A given score means the same for every group	Risk scoring and pricing	Can coexist with unequal error rates
Individual fairness	Similar people treated similarly	Case-by-case review	Requires defining 'similar'

WHEN IT MATTERS These measures are mathematically incompatible — you cannot satisfy all of them at once. Choosing which one fits the use case, and recording why, is a governance decision, not a technical one.

© 2026 Tertiary Infotech Academy Pte Ltd

Mitigating Bias Across the Lifecycle (A5)

1. **Examine the data**
   Provenance, representation, proxy features
2. **Choose the measure**
   Fairness metric fixed BEFORE testing
3. **Test by group**
   Aggregate accuracy hides group error
4. **Human review**
   Where a decision materially affects a person
5. **Monitor for drift**
   Fair at launch is not fair forever

VERIFY, DON'T ASSERT

A mitigation is only real if you can show the differential error rate fell. Use AI Verify to produce that evidence, and have it reviewed by someone who did not build the model (NIST MEASURE 1.3).

© 2026 Tertiary Infotech Academy Pte Ltd

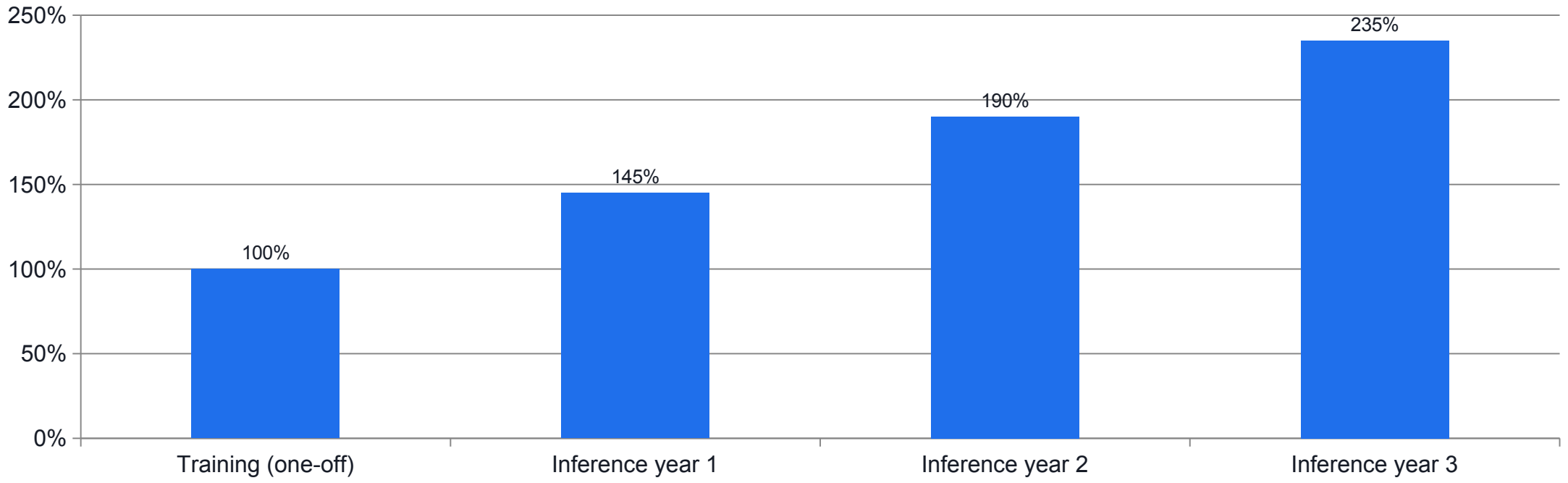
The Privacy–Performance Trade-off (A2)

Technique	Privacy gain	Performance cost	When to use it
Drop unneeded fields	High — the data is simply gone	Usually none	Always. Do this first; it is close to free
Generalise (bands, districts)	Moderate to high	Small to moderate	Quasi-identifiers that still carry signal
Hash / pseudonymise	Limited — still personal data	None for modelling	Joining records without holding the identifier
Aggregation	High	Moderate	Reporting and analytics, not per-person decisions
Differential privacy	Very high, and measurable	Material, grows with the guarantee	Secondary analysis; rarely a safety-critical model
Federated learning	High — data stays local	Moderate, plus complexity	Data that legally cannot be centralised

WHEN IT MATTERS There is no option that is free on both sides. Decide where on the curve you sit, record the reasoning, and have the data owner and the DPO both sign it — an unrecorded trade-off is a decision nobody made.

© 2026 Tertiary Infotech Academy Pte Ltd

Where the Energy Goes (K1, A9)



WHAT THE DATA SHOWS

Training is the visible one-off cost; inference is small per request but recurs on every request, so for a widely used deployed system it overtakes training and keeps growing. Illustrative shape for teaching the principle — measure your own.

© 2026 Tertiary Infotech Academy Pte Ltd

Assessing the Energy Footprint (K1, A9)

1

What to measure

Energy per inference (kWh per 1,000 requests) x request volume, plus training or fine-tuning as a periodic cost.

2

Beyond electricity

Water for data-centre cooling, and the embodied carbon of manufacturing and disposing of the hardware.

3

Where and when it runs

Grid carbon intensity varies by region and by time of day — the same workload has different footprints in different places.

4

Right-size the model

The single biggest lever. A large reasoning model used for routine classification multiplies energy for no benefit.

5

Cut needless inference

Cache repeated answers, batch, shorten prompts and outputs, and remove AI where a rule or a lookup would do.

6

Measure and report

NIST AI 600-1 lists Environmental Impacts as a GenAI risk — it belongs in the risk register, not only the sustainability report.

© 2026 Tertiary Infotech Academy Pte Ltd

Communicating Capabilities and Limitations Honestly (K4)

1

Why it matters

A model sounds equally confident whether it is right or wrong. Users calibrate trust on how you describe the system, so overstating it directly causes over-reliance.

2

Confabulation

NIST's name for confidently stated false content. It is a property of how these models work, not a bug you can fully remove.

3

Human-AI configuration

The NIST risk covering over-reliance, poor handoff and humans rubber-stamping output. Design the human check; do not assume it.

4

Say what it is NOT for

The most useful disclosure. 'This does not provide medical, legal or financial advice' prevents more harm than a capability list.

5

Publish a model or system card

Purpose, data, performance, limitations and intended use — the 'food label' the MGF's trusted-development dimension calls for.

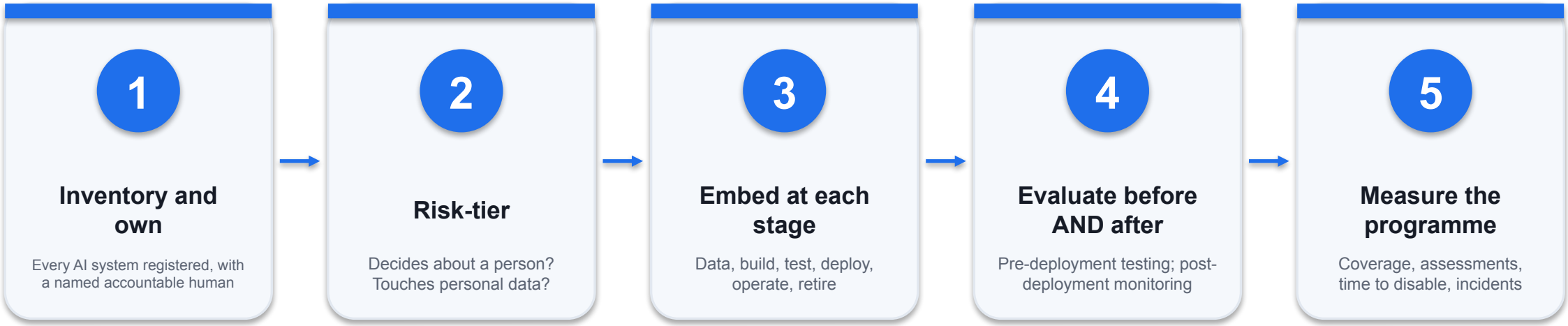
6

Give an escalation route

An obvious, easy path to a human. Transparency without a route to a person is only a disclaimer.

© 2026 Tertiary Infotech Academy Pte Ltd

Integrating Ethics Into Development and Evaluation (A1)



THE STRATEGY IN ONE LINE

Ethics is integrated when it is a GATE and a METRIC — something a system must pass to ship and something you report on afterwards — not a principle in a document nobody consults.

© 2026 Tertiary Infotech Academy Pte Ltd

Applying Ethical Guidelines to a Live System (A3)

1

Fairness

Test performance across the groups the system affects, and give anyone it serves poorly an accessible route to a human.

2

Accountability

A distinct identity per system with scoped credentials, a named owner in the inventory, and logging that makes actions attributable.

3

Transparency

Disclose AI use, state what the system is not for, publish a model or system card, and notify meaningfully where personal data is used.

4

Sustainability

Right-size the model, cut needless inference, and measure and report the footprint.

5

Security

Break the lethal trifecta, apply least privilege and a permission ladder, and gate irreversible actions.

6

Proportionality

Scale all of the above to the system's risk tier — full assurance on a meeting summariser exhausts the goodwill you need for the credit model.

© 2026 Tertiary Infotech Academy Pte Ltd

Championing Responsible AI in Your Organisation (A7)

1

Role-specific training

Generic awareness changes nothing. Give each group its real tasks — what an administrator may enter, when a professional must not rely on output.

2

Make the right path the easy path

A sanctioned toolset, a fast approval route with a real service level, and templates. Governance that obstructs is governance that is bypassed.

3

Use your own near-misses

Your organisation's own incident is far more persuasive than any external example.

4

Label AI-generated content

Content provenance — MGF dimension 7. Disclose, and review before publication where the audience could be harmed.

5

Report results, not intentions

Commit publicly to testing before deployment and monitoring after it, and publish what the tests found.

6

Lead with the enabler argument

Governed organisations deploy FASTER, because approval and evidence become routine instead of bespoke every time.

© 2026 Tertiary Infotech Academy Pte Ltd

01

TOPIC 01

AI Security Governance Foundations and Business Risks

Why AI changes the risk picture · the AI threat landscape · GenAI and agentic risk · the business case

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — AI Security Governance Foundations and Business Risks

1

AI security governance defined

The system of policies, roles, controls and evidence that keeps AI systems secure, lawful and accountable — distinct from, but built on, existing information-security governance.

2

Why AI breaks the old model

Traditional controls assume deterministic software with a fixed attack surface. AI systems learn from data, behave probabilistically, and — when agentic — take actions in live systems.

3

The expanded attack surface

AI adds five new asset classes to protect: training data, the model itself, prompts and context, the inference endpoint, and the tools an agent can invoke.

4

Traditional vs AI-specific threats

SQL injection, XSS and weak credentials still apply. Prompt injection, data poisoning, model inversion, membership inference and model theft are new.

5

The NIST GenAI risk set

NIST AI 600-1 names 12 risks unique to or exacerbated by generative AI, including confabulation, data privacy, information security, information integrity and value-chain risk.

6

Agentic AI raises the stakes

An agent that can read private data, ingest untrusted content and communicate externally forms the 'lethal trifecta' — the pattern behind most 2025–2026 agent breaches.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — AI Security Governance Foundations and Business Risks (continued)

1

Real incidents, real losses

EchoLeak (CVE-2025-32711, CVSS 9.3) exfiltrated M365 Copilot context with zero user interaction; an over-scoped token let malicious instructions reach a build pipeline.

2

Shadow AI is the default state

Staff adopt AI tools faster than governance can approve them; an unowned, uninventoried AI system is the single most common governance failure in businesses.

3

Business impact, not technical impact

AI risk translates into regulatory penalties, contractual breach, IP leakage, reputational harm, service failure and unsafe automated decisions about people.

4

The Singapore context

Businesses here must satisfy the PDPA, the PDPC AI Advisory Guidelines, IMDA's Model AI Governance Framework for Generative AI and AI Verify testing expectations.

5

Governance is a business enabler

Organisations with mature AI governance deploy faster, because approval, evidence and assurance are routine rather than bespoke for every project.

6

The AI TRiSM market signal

AI Trust, Risk and Security Management is one of the fastest-growing security segments — evidence that governance spend is now a board-level line item.

© 2026 Tertiary Infotech Academy Pte Ltd

LO1 · THE FIRST THING YOU WILL FIND

Shadow AI — The Governance Problem You Already Have

1

It is the norm, not the exception

Staff adopt AI faster than any approval process. Assume it is happening and go looking, rather than assuming it is not.

2

It bypasses every control

No DLP, no logging, no retention limit, no contract, no assurance — because the tool was never registered.

3

Where to find it

Expense claims and department cards, SaaS AI features switched on by default, browser extensions, and an honest anonymous staff survey.

4

Embedded AI counts

M365 Copilot, Zoom AI Companion, Gong and ServiceNow Now Assist are AI systems even though nobody 'bought AI'.

5

The wrong response

Blanket bans push usage further underground. Provide a sanctioned, easy route and the shadow shrinks.

6

The right first control

An inventory with named owners. You cannot risk-assess, monitor or govern what you have not listed.

© 2026 Tertiary Infotech Academy Pte Ltd

Reading an Incident: What Actually Failed

Incident	Surface cause	The governance control that was missing
EchoLeak (M365 Copilot, CVSS 9.3)	Injected instruction in an e-mail	Untrusted content reached a context with private data and an outbound path
Build-pipeline instruction injection	Malicious system-prompt file	Over-scoped token; agent-authored change merged without review
Unauthenticated MCP server (CVSS 9.1)	No auth at the tool boundary	Tool exposed without authentication — no model involvement needed
Config override in a coding agent	Repo-defined settings overrode user approval	Project-level config trusted above user consent; hooks ran pre-authentication
Dependency compromise	Malicious package version	No version pinning; automation multiplied the blast radius in hours

WHEN IT MATTERS In none of these did the model 'go rogue'. Every one was a failure of authorisation, scope or supply chain — which is to say, a governance failure.

© 2026 Tertiary Infotech Academy Pte Ltd

Building the Business Case

1

Lead with exposure, not technology

Boards fund risk reduction and revenue protection. They do not fund frameworks.

2

Quantify one scenario properly

One credible, costed scenario beats a list of ten vague ones. Show your assumptions so they can be challenged.

3

Name the regulatory exposure

PDPA penalties and supervisory consequences are concrete numbers a board already understands.

4

Use the enabler argument

Governed organisations deploy faster because approval and evidence are routine rather than bespoke each time.

5

Ask for one thing

Budget, headcount or mandate. A paper with three asks gets none of them.

6

Prepare the tool question

'Why not just buy a tool?' — because a tool with no inventory, no owner and no policy has nothing to enforce.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — AI Security Governance Foundations and Business Risks

Labs 1–2

- Build the AI System Inventory for NovaBank
- Map the AI Threat Landscape with the Threat Simulator

Labs 3–4

- Analyse the Lethal Trifecta in a Live Agent Design
- Build the Business Case for AI Security Governance

—

- —

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 01 · HANDS-ON

Build the AI System Inventory for NovaBank

LAB 1

Analyse an organisation's AI footprint and produce the AI system inventory that every other governance control depends on.

You are the newly appointed AI Governance Lead at NovaBank, a mid-sized Singapore retail bank. Nobody can tell you how many AI systems the bank runs. You will work from the supplied discovery pack — an IT asset extract, a procurement export and a staff survey — to identify every AI system, classify it, and produce a defensible AI system inventory with named owners and risk tiers.

YOU'LL BUILD

A completed AI System Inventory (ai-inventory.csv) covering 12 AI systems with owner, purpose, data classes, model, autonomy level and risk tier, plus a shadow-AI findings note.

TOOLCHAIN

Mock data pack (discovery-it-assets.csv, discovery-procurement.csv, discovery-staff-survey.csv), spreadsheet tool

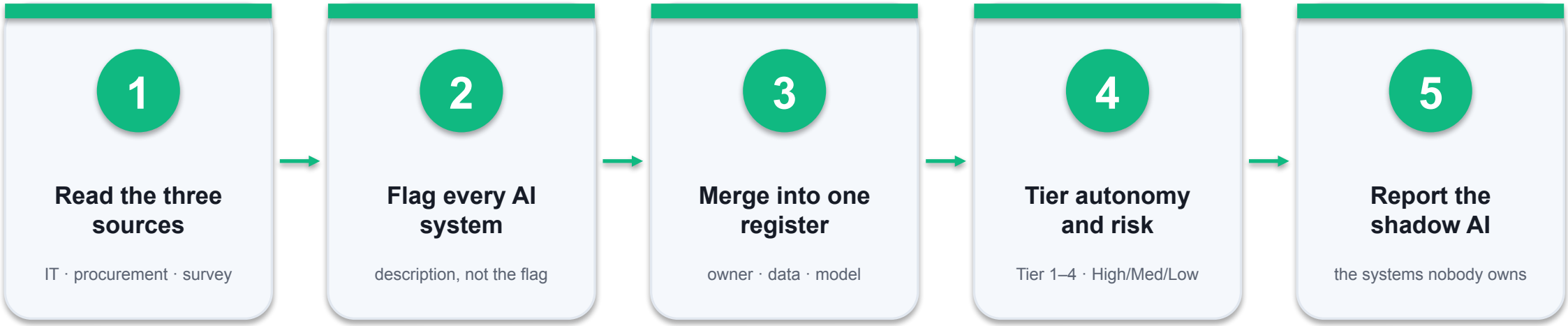
DONE WHEN

Your inventory has a row for every AI system in all three files, including at least three shadow-AI tools that appear only in the staff survey. Every row has a named owner, an autonomy tier and a risk tier, and you can justify each High rating in one sentence.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1 · PROCESS MAP

How Lab 1 Runs



THE POINT

Analyse an organisation's AI footprint and produce the AI system inventory that every other governance control depends on.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1 · VERIFY

Build the AI System Inventory for NovaBank

✅ Expected result

Your inventory has a row for every AI system in all three files, including at least three shadow-AI tools that appear only in the staff survey. Every row has a named owner, an autonomy tier and a risk tier, and you can justify each High rating in one sentence.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 01 · HANDS-ON

Map the AI Threat Landscape with the Threat Simulator

LAB 2

Analyse how traditional security threats and AI-specific threats combine in an AI-enabled business, and explain the business impact of each.

Governance decisions are only as good as your understanding of the threats. You will use the browser-based Cybersecurity Threat Simulator to experience the classic attack classes hands-on, then extend each one into its AI-era equivalent and record the business impact for NovaBank.

YOU'LL BUILD

A completed Threat-to-Business-Impact map covering 8 threat classes, each with its AI-era variant, the NovaBank asset at risk and a first-line control.

TOOLCHAIN

Cybersecurity Threat Simulator (https://alfredang.github.io/cybersecuritysimulator/), threat-map worksheet

DONE WHEN

Your map has all eight threat classes with both the traditional and the AI-era variant filled in. You can state, from the simulator, why parameterised queries stop SQL injection, and explain in one sentence why the same reasoning does not fully stop prompt injection.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2 · PROCESS MAP

How Lab 2 Runs

1. **Run the simulator modules**
   phishing · SQLi · XSS
2. **Record what you observed**
   the mechanism, not the term
3. **Test passwords and social**
   entropy · crack time
4. **Model the data leakage**
   toggle each control
5. **Map to AI-era variants**
   and the business impact

THE POINT

Analyse how traditional security threats and AI-specific threats combine in an AI-enabled business, and explain the business impact of each.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2 · VERIFY

Map the AI Threat Landscape with the Threat Simulator

✅ Expected result

Your map has all eight threat classes with both the traditional and the AI-era variant filled in. You can state, from the simulator, why parameterised queries stop SQL injection, and explain in one sentence why the same reasoning does not fully stop prompt injection.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 01 · HANDS-ON

Analyse the Lethal Trifecta in a Live Agent Design

LAB 3

Analyse an agentic AI design, identify the lethal-trifecta exposure and the applicable NIST GenAI risks, and propose an architectural break.

NovaBank's digital team has proposed 'NovaAssist', a customer-service agent that reads the customer's account, searches incoming e-mail and web content for context, and can send e-mails and raise payment instructions. You will analyse the design against the lethal trifecta and the NIST AI 600-1 GenAI risk set, and recommend a redesign.

YOU'LL BUILD

A completed agent risk analysis: the trifecta assessment, five mapped NIST GenAI risks, a documented attack path and a redesign that breaks the trifecta.

TOOLCHAIN

NovaAssist design brief (novassist-design-brief.md), NIST AI 600-1 risk list, trifecta worksheet

DONE WHEN

You can state which of the three legs your redesign removes and why removing that leg is more effective than adding an output filter to the original design. Your five NIST risks are each tied to a concrete NovaBank consequence, not a generic description.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3 · PROCESS MAP

How Lab 3 Runs

1. **Read the design brief**
   every source, every action
2. **Test the three legs**
   private · untrusted · outbound
3. **Write the attack path**
   the EchoLeak pattern
4. **Map five NIST risks**
   with business impact
5. **Break a leg, not a filter**
   then state residual risk

THE POINT

Analyse an agentic AI design, identify the lethal-trifecta exposure and the applicable NIST GenAI risks, and propose an architectural break.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3 · VERIFY

Analyse the Lethal Trifecta in a Live Agent Design

✅ Expected result

You can state which of the three legs your redesign removes and why removing that leg is more effective than adding an output filter to the original design. Your five NIST risks are each tied to a concrete NovaBank consequence, not a generic description.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 01 · HANDS-ON

Build the Business Case for AI Security Governance

LAB 4

Analyse the cost of inaction and present a business case that justifies AI security governance investment to a board.

Governance competes for budget. You will quantify NovaBank's exposure using the incident pack and the cost assumptions provided, then produce a one-page board paper that argues for the governance programme in the language executives use: risk reduction, regulatory exposure and time to deploy.

YOU'LL BUILD

A one-page board paper with a quantified exposure estimate, three prioritised investments and the expected risk reduction for each.

TOOLCHAIN

Incident cost pack (incident-cost-assumptions.csv, sector-incident-data.csv), board paper template

DONE WHEN

Your board paper fits on one page, states a number for annual expected loss with its assumptions visible, and each of the three investments names the specific risk it reduces. You can answer the CFO challenge 'why not just buy a tool?' in one sentence.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4 · PROCESS MAP

How Lab 4 Runs

1. **Open the cost pack**
   four cost categories
2. **Count your High-risk systems**
   from the Lab 1 inventory
3. **Cost one real scenario**
   likelihood × impact
4. **Pick three investments**
   cost · time · risk cut
5. **Write the board paper**
   one page, one ask

THE POINT

Analyse the cost of inaction and present a business case that justifies AI security governance investment to a board.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4 · VERIFY

Build the Business Case for AI Security Governance

✅ Expected result

Your board paper fits on one page, states a number for annual expected loss with its assumptions visible, and each of the three investments names the specific risk it reduces. You can answer the CFO challenge 'why not just buy a tool?' in one sentence.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC RECAP

Recap — AI Security Governance Foundations and Business Risks

- You can now: Analyse an organisation's AI footprint and produce the AI system inventory that every other governance control depends on.
- You can now: Analyse how traditional security threats and AI-specific threats combine in an AI-enabled business, and explain the business impact of each.
- You can now: Analyse an agentic AI design, identify the lethal-trifecta exposure and the applicable NIST GenAI risks, and propose an architectural break.
- You can now: Analyse the cost of inaction and present a business case that justifies AI security governance investment to a board.

© 2026 Tertiary Infotech Academy Pte Ltd

02

TOPIC 02

Building an AI Governance Framework: Policies, Roles and Risk Ownership

NIST AI RMF · MGF for GenAI · PDPA duties · policy architecture · roles, RACI and the AI inventory

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Building an AI Governance Framework: Policies, Roles and Risk Ownership

1

NIST AI RMF 1.0 at a glance

A voluntary framework structured as four functions — GOVERN, MAP, MEASURE, MANAGE — that any organisation can adopt without buying a product.

2

The seven trustworthiness characteristics

Valid and reliable; safe; secure and resilient; accountable and transparent; explainable and interpretable; privacy-enhanced; and fair with harmful bias managed.

3

GOVERN — the cross-cutting function

GOVERN 1 policies and legal duties, GOVERN 2 accountability and training, GOVERN 3 diverse teams, GOVERN 4 risk culture, GOVERN 5 stakeholder engagement, GOVERN 6 third-party risk.

4

MAP, MEASURE and MANAGE

MAP frames context and risk; MEASURE selects metrics and tests; MANAGE prioritises, treats, monitors and responds to risks including third-party and residual risk.

5

Singapore's MGF for Generative AI

IMDA and AI Verify Foundation set nine dimensions: accountability, data, trusted development and deployment, incident reporting, testing and assurance, security, content provenance, safety R&D and public good.

6

AI Verify — testing as evidence

Singapore's AI governance testing framework and toolkit lets an organisation demonstrate, not merely assert, that a system behaves as claimed.

7

PDPA duties that bite on AI

Consent and Notification, Accountability, Protection and Retention obligations apply whenever personal data is used to develop or run an AI system.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Building an AI Governance Framework: Policies, Roles and Risk Ownership (continued)

1

Business Improvement and Research exceptions

The PDPC guidelines explain when personal data may be used without fresh consent to develop AI systems — and the conditions and documentation that must accompany that reliance.

2

Policy architecture, not a single policy

A workable set is an AI acceptable-use policy, an AI risk-management standard, a data-for-AI standard, a model/agent development standard, and a third-party AI standard.

3

Roles and risk ownership

Board and executive accountability, an AI governance committee, business system owners, model owners, the DPO, security, legal, and a named human accountable for each deployment.

4

RACI beats goodwill

Every control needs a Responsible doer, an Accountable owner, Consulted specialists and Informed stakeholders — ambiguity is where AI governance quietly fails.

5

The AI system inventory

You cannot govern what you cannot see: a register of every AI system with owner, purpose, data classes, model, tools, risk tier and review date is the foundational control.

6

Risk tiering drives proportionality

Classify systems by impact on people and business, then scale the control set — light-touch for low-risk internal aids, full assurance for decisions affecting individuals.

© 2026 Tertiary Infotech Academy Pte Ltd

LO2 · FIVE DOCUMENTS, NOT ONE

What a Workable Policy Set Looks Like

1

AI Acceptable Use Policy

For everyone. What staff may and may not do, with which tools and which data. Short enough to be read.

2

AI Risk Management Standard

Risk tiering, the assessment required per tier, who signs off, and the review cycle.

3

Data for AI Standard

Provenance, lawful basis, classification, minimisation, de-identification and retention.

4

Model & Agent Development Standard

Threat modelling, testing, red-teaming, human-oversight design and change control.

5

Third-Party AI Standard

Vendor due diligence, model provenance questions, sub-processor disclosure and contractual terms.

6

One page beats twenty

A policy nobody reads is worse than none — it creates the illusion of control.

© 2026 Tertiary Infotech Academy Pte Ltd

The Five Policy Defects That Make Policies Fail

1

Vague scope

'This policy covers AI' — does it cover Copilot? Personal ChatGPT? An AI feature in a SaaS you already own? Say so.

2

No approval turnaround

A pathway with no service level is a pathway staff bypass. Commit to a number of days.

3

Prohibitions without alternatives

Ban a tool without providing a sanctioned route and usage moves underground, not away.

4

No named owner

A policy with no owner and no review date is already obsolete on the day it is issued.

5

Unenforceable clauses

If you cannot detect a breach, the clause is advice. Pair each rule with the control that evidences it.

6

The test

Could a member of staff read it and know exactly what to do on Monday morning?

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Tiering Drives Everything Else

1

Two questions

Does it decide about a person? Does it touch personal or confidential data?

2

Assign a tier

High, Medium or Low — recorded in the inventory

3

Scale the controls

Assessment depth, testing, oversight and approver rise with the tier

4

Set the review cycle

High reviewed most often; Low on a light-touch cycle

5

Proportionate governance

Effort follows risk, so the process survives contact with the business

THE FAILURE MODE

Treating every AI system the same. Full assurance on a meeting-summariser exhausts the goodwill you need for the credit model.

© 2026 Tertiary Infotech Academy Pte Ltd

Roles and Risk Ownership

1

Board / Executive

Owns AI risk appetite and is accountable for decisions about AI risk (NIST GOVERN 2.3). Not delegable.

2

AI Governance Committee

Decides. If it can only advise, it cannot govern — write decision rights into the terms of reference.

3

AI Governance Lead

Runs the programme: inventory, assessments, reporting. Coordinates; does not own every system.

4

AI System Owner

A named business person accountable for one system's purpose, risk and behaviour.

5

Data Protection Officer

Lawful basis, notification, individual rights and breach determination.

6

Security Lead

Threat modelling, testing, monitoring, incident response and the kill switch.

© 2026 Tertiary Infotech Academy Pte Ltd

LO2 · REMOVING AMBIGUITY

The Single-A Rule and Why RACI Fails Without It

1

R — Responsible

Does the work. There can be several.

2

A — Accountable

Answers for the outcome. There must be exactly ONE.

3

C — Consulted

Two-way: their input is sought before the decision.

4

I — Informed

One-way: told after the decision.

5

Two A's means none

When two roles are accountable, each assumes the other has it. This is discovered during an incident, at the worst possible moment.

6

The stress test

Walk a real incident through your RACI. Every step must produce a named person.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Building an AI Governance Framework: Policies, Roles and Risk Ownership

Labs 5–6

- Run a NIST AI RMF Gap Assessment
- Draft the AI Acceptable Use and Governance Policy Set

Labs 7–8

- Design the Governance Operating Model and RACI
- Apply the PDPA and PDPC AI Advisory Guidelines

—

- —

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 02 · HANDS-ON

Run a NIST AI RMF Gap Assessment

LAB 5

Evaluate an organisation against the NIST AI RMF GOVERN, MAP, MEASURE and MANAGE functions and produce a prioritised gap register.

NovaBank has an information-security programme but no AI-specific governance. You will assess the bank against the NIST AI RMF using the supplied evidence pack — policy extracts, meeting minutes and interview notes — scoring each subcategory and producing a gap register that drives the rest of the course.

YOU'LL BUILD

A completed NIST AI RMF gap assessment across 16 subcategories, each scored with evidence, plus a top-10 prioritised gap register.

TOOLCHAIN

Evidence pack (policy-extracts.md, governance-interviews.md, existing-controls.csv), RMF assessment worksheet

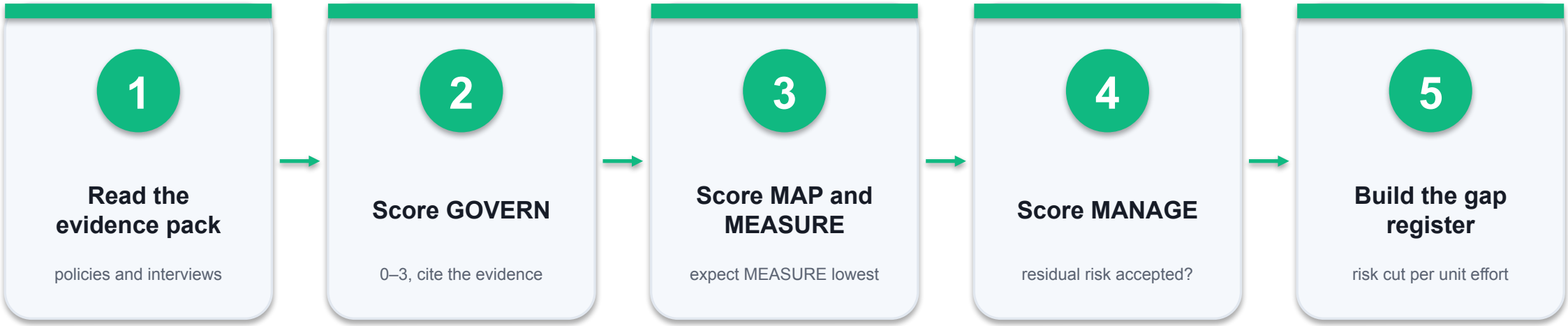
DONE WHEN

Every subcategory score cites a specific line of evidence from the pack. Your gap register's top three items are all High-risk, and you can defend why a lower-scoring subcategory did not make the top ten.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5 · PROCESS MAP

How Lab 5 Runs



THE POINT

Evaluate an organisation against the NIST AI RMF GOVERN, MAP, MEASURE and MANAGE functions and produce a prioritised gap register.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5 · VERIFY

Run a NIST AI RMF Gap Assessment

✅ Expected result

Every subcategory score cites a specific line of evidence from the pack. Your gap register's top three items are all High-risk, and you can defend why a lower-scoring subcategory did not make the top ten.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 02 · HANDS-ON

Draft the AI Acceptable Use and Governance Policy Set

LAB 6

Evaluate policy requirements and develop an enforceable AI policy set aligned to the NIST AI RMF and Singapore's MGF for Generative AI.

Policy is where governance becomes enforceable. You will draft NovaBank's AI Acceptable Use Policy and the supporting standard, working from the gap register you produced in Lab 5 and the nine dimensions of Singapore's Model AI Governance Framework for Generative AI.

YOU'LL BUILD

A complete AI Acceptable Use Policy (2 pages) plus a one-page AI Risk Management Standard, both mapped to MGF dimensions and RMF subcategories.

TOOLCHAIN

Policy templates (aup-template.md, standard-template.md), MGF nine dimensions reference, Lab 5 gap register

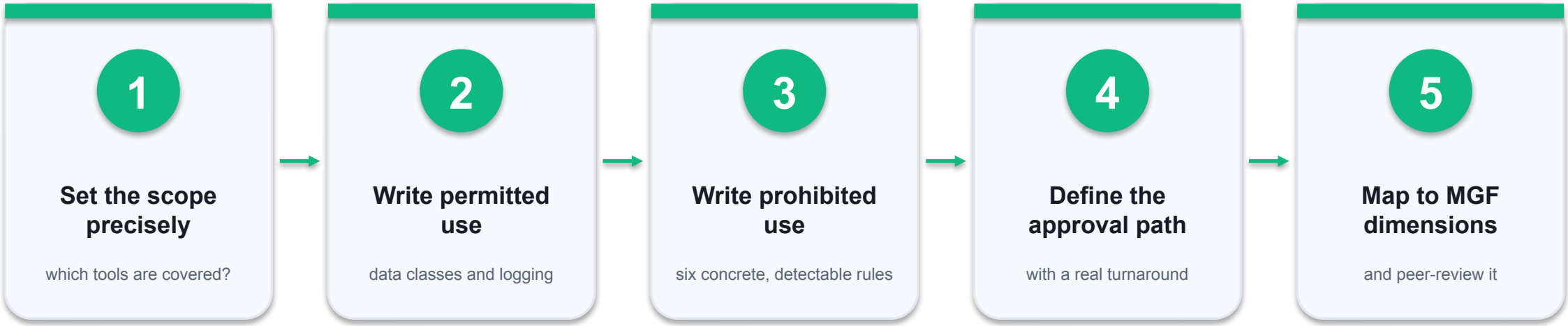
DONE WHEN

Your AUP states at least six concrete prohibited actions, names the approver and the turnaround time, and every clause maps to at least one MGF dimension. A peer confirms they could apply your policy without asking you a question.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6 · PROCESS MAP

How Lab 6 Runs



THE POINT

Evaluate policy requirements and develop an enforceable AI policy set aligned to the NIST AI RMF and Singapore's MGF for Generative AI.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6 · VERIFY

Draft the AI Acceptable Use and Governance Policy Set

✅ Expected result

Your AUP states at least six concrete prohibited actions, names the approver and the turnaround time, and every clause maps to at least one MGF dimension. A peer confirms they could apply your policy without asking you a question.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 02 · HANDS-ON

Design the Governance Operating Model and RACI

LAB 7

Evaluate accountability requirements and develop a governance operating model with committee structure, roles and a control-level RACI.

Policies fail without owners. You will design NovaBank's AI governance operating model: the committee that decides, the roles that execute, and a RACI matrix that removes ambiguity from the twelve controls you have identified so far.

YOU'LL BUILD

A governance operating model diagram, committee terms of reference, six role descriptions and a RACI matrix covering twelve AI governance controls.

TOOLCHAIN

Org chart (novabank-org-chart.md), role catalogue, RACI template

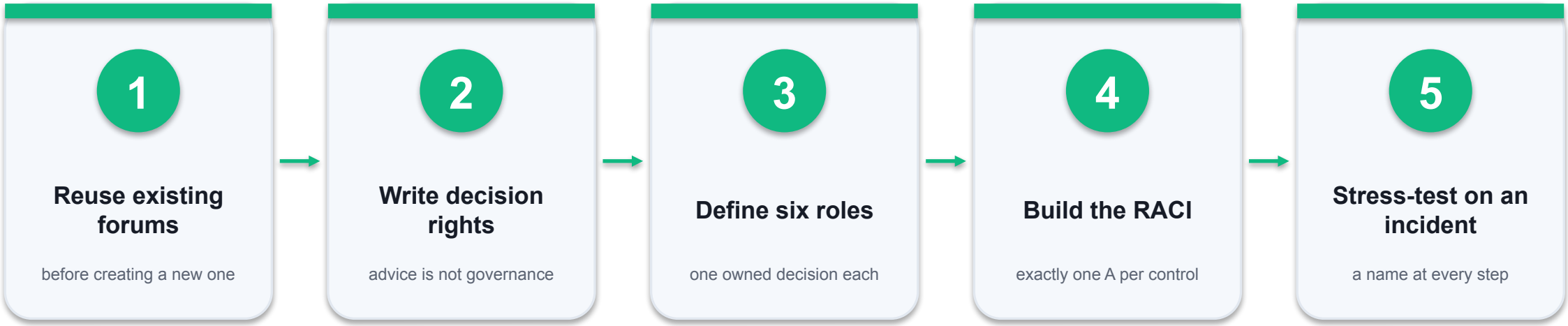
DONE WHEN

Every one of the twelve controls has exactly one Accountable role. Walking the NovaAssist incident through your model produces a named person at every step, with no gaps and no two people claiming the same decision.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7 · PROCESS MAP

How Lab 7 Runs



THE POINT

Evaluate accountability requirements and develop a governance operating model with committee structure, roles and a control-level RACI.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7 · VERIFY

Design the Governance Operating Model and RACI

✅ Expected result

Every one of the twelve controls has exactly one Accountable role. Walking the NovaAssist incident through your model produces a named person at every step, with no gaps and no two people claiming the same decision.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 02 · HANDS-ON

Apply the PDPA and PDPC AI Advisory Guidelines

LAB 8

Evaluate the lawful basis for using personal data in AI systems under Singapore's PDPA and apply the PDPC AI advisory guidelines to four scenarios.

Singapore-specific compliance is where many AI projects stall. You will assess four NovaBank AI use cases against the PDPA obligations and the PDPC Advisory Guidelines on the Use of Personal Data in AI Recommendation and Decision Systems, and determine the lawful basis and the required notifications.

YOU'LL BUILD

A PDPA compliance determination for four AI use cases, each with lawful basis, required notification, accountability measures and documentation.

TOOLCHAIN

PDPA scenario pack (pdpa-scenarios.md), PDPC guidelines summary, determination worksheet

DONE WHEN

Each of the four scenarios has a stated lawful basis with a reason. You can explain the difference between the Business Improvement Exception and the Research Exception in one sentence, and say which scenario needs the strongest human-oversight measure and why.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8 · PROCESS MAP

How Lab 8 Runs



THE POINT

Evaluate the lawful basis for using personal data in AI systems under Singapore's PDPA and apply the PDPC AI advisory guidelines to four scenarios.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8 · VERIFY

Apply the PDPA and PDPC AI Advisory Guidelines

✅ Expected result

Each of the four scenarios has a stated lawful basis with a reason. You can explain the difference between the Business Improvement Exception and the Research Exception in one sentence, and say which scenario needs the strongest human-oversight measure and why.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC RECAP

Recap — Building an AI Governance Framework: Policies, Roles and Risk Ownership

- You can now: Evaluate an organisation against the NIST AI RMF GOVERN, MAP, MEASURE and MANAGE functions and produce a prioritised gap register.
- You can now: Evaluate policy requirements and develop an enforceable AI policy set aligned to the NIST AI RMF and Singapore's MGF for Generative AI.
- You can now: Evaluate accountability requirements and develop a governance operating model with committee structure, roles and a control-level RACI.
- You can now: Evaluate the lawful basis for using personal data in AI systems under Singapore's PDPA and apply the PDPC AI advisory guidelines to four scenarios.

© 2026 Tertiary Infotech Academy Pte Ltd

03

TOPIC 03

Governance Controls Across the AI Lifecycle

Data governance · secure development · testing and red-teaming · deployment · monitoring · incident response · decommissioning

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Governance Controls Across the AI Lifecycle

1

The AI lifecycle as a control surface

Plan, source data, develop, test, deploy, operate and monitor, then decommission — each stage has its own failure modes and its own controls.

2

Data governance for AI

Provenance, lawful basis, quality, classification, minimisation, de-identification, retention and deletion — decided before a model is trained, not after.

3

Personal data in AI systems

Under the PDPC guidelines, organisations should apply data-protection measures such as minimisation, anonymisation and access control when using personal data in AI development.

4

Data poisoning and supply chain

Training and fine-tuning data, embeddings, third-party models and packages are all supply-chain entry points; pin versions and validate sources.

5

Secure AI development

Threat-model the system, protect prompts and secrets, isolate environments, review AI-generated code, and control who can change a model or instruction.

6

Testing, evaluation and assurance

Functional accuracy is not enough: test robustness, bias, privacy leakage, jailbreak resistance and grounding before release, and record the evidence.

7

Red-teaming AI systems

Adversarial testing against prompt injection, jailbreaks, data leakage and unsafe tool use — run before production and after every significant change.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Governance Controls Across the AI Lifecycle (continued)

1

Deployment gates

A go/no-go decision with named approvers, documented residual risk, rollback plan, and a transparency notice where individuals are affected.

2

Human oversight by design

Define where a human reviews, approves or can override, and make the escalation path fast enough to actually be used.

3

Continuous monitoring

Watch drift, output quality, refusal and jailbreak rates, cost, latency and anomalous access — AI risk changes after deployment, not just before.

4

Logging and auditability

Retain prompts, outputs, tool calls, approvals and model versions to the extent lawful, so an incident can be reconstructed and a decision explained.

5

AI incident response

Extend the existing IR plan: how to disable an AI system fast, preserve evidence, assess personal-data impact, and notify under the PDPA where required.

6

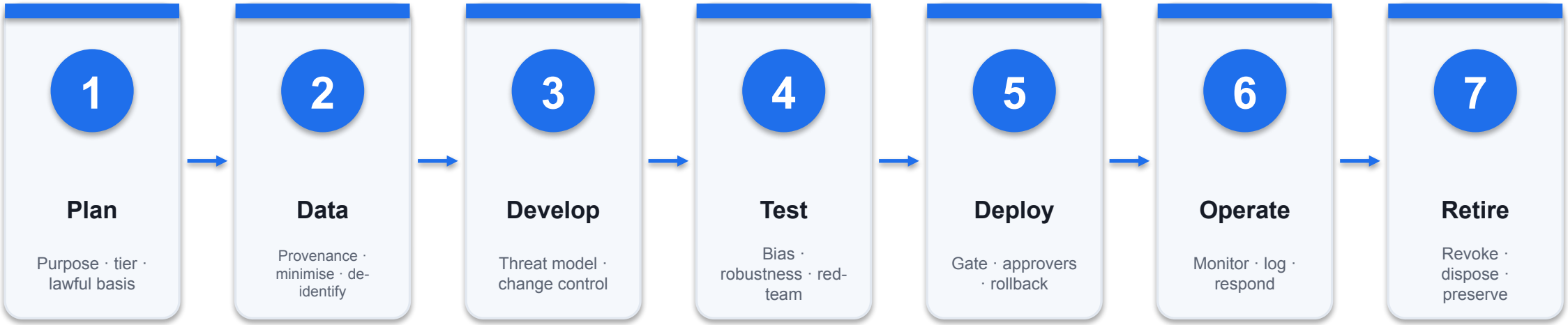
Decommissioning safely

Retire models and agents deliberately — revoke credentials, dispose of memory and embeddings, preserve audit logs and update dependent systems.

© 2026 Tertiary Infotech Academy Pte Ltd

LO3 · EVERY STAGE HAS ITS OWN FAILURE MODE

The AI Lifecycle as a Control Surface



WHERE GOVERNANCE USUALLY STOPS

At deploy. Which is precisely where AI risk begins to change, because the data, the model and the usage all drift.

© 2026 Tertiary Infotech Academy Pte Ltd

Data Governance for AI — Decisions Made Before Training

1

Provenance

Where did every field come from, and were we permitted to collect it for this purpose?

2

Lawful basis

Consent, or a recorded exception. Decide and document it before the data moves, not after the model works.

3

Minimisation

Does the model actually need this field to do its job? Most training sets carry fields nobody can justify.

4

Classification

Direct identifier, quasi-identifier, sensitive attribute or non-personal — the class drives the treatment.

5

De-identification

Remove, hash, generalise or retain. Note that encryption is reversible and so remains personal data to the key holder.

6

Retention and deletion

How long the training set lives, and what happens to the model when an individual exercises deletion.

© 2026 Tertiary Infotech Academy Pte Ltd

Protecting Data — Which Technique, For What

Technique	What it gives you	Reversible?	Still personal data?	Use it for
Deletion / omission	The field is simply gone	No	No	Anything the model does not need
Generalisation	Age band instead of date of birth	No	Reduced risk	Quasi-identifiers with predictive value
Hashing	A consistent pseudonym	No (but linkable)	Yes — it is pseudonymisation	Joining records without holding the identifier
Encryption (AES)	Confidentiality in storage/transit	Yes, with the key	Yes, to the key holder	Protecting data at rest and in transit
Asymmetric (RSA)	Safe key exchange	Yes, with the private key	Depends	Moving keys and data between environments
Signing (ECDSA)	Integrity and origin proof	N/A	N/A	Proving the training set was not altered after approval

WHEN IT MATTERS The most common mistake: calling a hashed or encrypted dataset 'anonymised'. It is pseudonymised, and PDPA obligations continue to apply.

© 2026 Tertiary Infotech Academy Pte Ltd

Testing an AI System — Beyond 'Does It Answer Correctly?'

1. **Accuracy and reliability**
   Does it perform in the conditions it will actually meet, not just on the test set?

2. **Robustness**
   How does it behave on edge cases, adversarial input and malformed data?

3. **Bias and fairness**
   Does performance differ across groups? Test it; do not assume the data was neutral.

4. **Privacy leakage**
   Can training data or another user's data be elicited from the output?

5. **Jailbreak resistance**
   Can the instruction be overridden by crafted input? Assume yes, and measure how easily.

6. **Grounding**
   Are claims traceable to a source, or is the model confabulating fluently?

© 2026 Tertiary Infotech Academy Pte Ltd

Red-Teaming an AI System

1

It is adversarial, not functional

Functional testing asks 'does it work?'. Red-teaming asks 'how do I make it misbehave?'

2

Direct prompt injection

Instructions typed by the user to override the system prompt.

3

Indirect injection

Instructions hidden in content the agent retrieves — e-mail, documents, web pages, even white-on-white text.

4

System-prompt extraction

Getting the agent to reveal its own instructions, which then makes every other attack easier.

5

Unsafe tool invocation

Inducing a permitted tool call with attacker-chosen parameters.

6

When to run it

Before production, and after every significant change — a new tool, a new data source, a model version bump.

© 2026 Tertiary Infotech Academy Pte Ltd

Monitoring — Because AI Risk Changes After Launch

1

Quality

Accuracy and groundedness drift as the world and the data move away from the training distribution.

2

Safety

Refusal rate and injection-detection rate. A metric with no threshold is a dashboard, not a control.

3

Operations

Latency, cost per call and error rate — the signals that surface a problem before customers do.

4

Security

Permission escalations, out-of-hours access, anomalous tool sequences and outbound sends.

5

Every alert needs an owner

Who is notified, what they check first, and the condition under which the system is disabled.

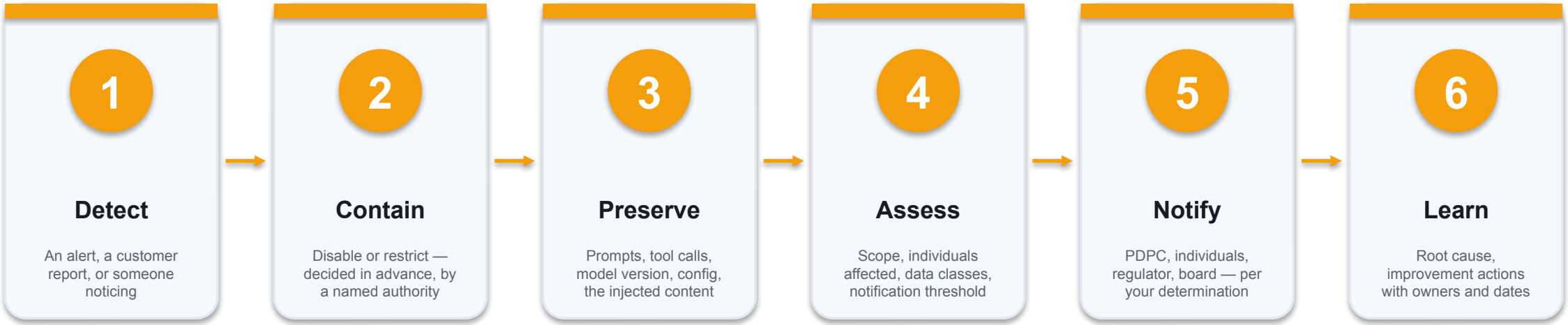
6

Time to disable

Measure it. You will be asked during an incident, and 'we're not sure' is not an answer.

© 2026 Tertiary Infotech Academy Pte Ltd

AI Incident Response



THE QUESTION THAT EXPOSES THE GAP

If your agent started leaking data at 09:00 on a Saturday, who switches it off, and how long does it take? Most organisations cannot answer.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Governance Controls Across the AI Lifecycle

Labs 9–10

- Govern the Data: Classification, Minimisation and Protection
- Red-Team an AI System Before Deployment

Labs 11–12

- Design Deployment Gates and Continuous Monitoring
- Run an AI Incident Response Exercise

—

- —

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 03 · HANDS-ON

Govern the Data: Classification, Minimisation and Protection

LAB 9

Develop and apply data governance controls for an AI training set, including classification, minimisation, de-identification and retention.

NovaBank wants to train a churn-prediction model on customer data. You will govern the dataset before a single model is trained: classify every field, strip what is not needed, de-identify what remains, and prove the protection using the Cryptography Toolkit for hashing and encryption.

YOU'LL BUILD

A governed training dataset specification: a field-by-field classification and minimisation decision, a de-identification method per field, and a tested hashing approach with retention rules.

TOOLCHAIN

Customer dataset (customer-training-data.csv, data-dictionary.md), Cryptography Toolkit (https://alfredang.github.io/cryptography-toolkit/)

DONE WHEN

You dropped at least eight fields with a stated reason, every retained personal field has a de-identification method, and you can explain to a business stakeholder why hashing an identifier is not the same as anonymising the record.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9 · PROCESS MAP

How Lab 9 Runs

1. **Classify all 24 fields**
   identifier · quasi · sensitive
2. **Minimise ruthlessly**
   does churn need it?
3. **Choose the method per field**
   remove · hash · generalise
4. **Test AES, RSA and ECDSA**
   encryption is reversible
5. **Set retention and deletion**
   and record the basis

THE POINT

Develop and apply data governance controls for an AI training set, including classification, minimisation, de-identification and retention.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9 · VERIFY

Govern the Data: Classification, Minimisation and Protection

✅ Expected result

You dropped at least eight fields with a stated reason, every retained personal field has a de-identification method, and you can explain to a business stakeholder why hashing an identifier is not the same as anonymising the record.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 03 · HANDS-ON

Red-Team an AI System Before Deployment

LAB 10

Develop pre-deployment assurance by red-teaming an AI application for injection, access-control and data-leakage weaknesses, and record the evidence.

Testing that a model is accurate is not assurance. You will run an adversarial pre-deployment test against the FauxBank training sandbox, find the vulnerability classes that matter for an AI-enabled banking application, and produce the test evidence a deployment gate requires.

YOU'LL BUILD

A pre-deployment red-team report: findings with severity, evidence and OWASP mapping, extended with the AI-specific test cases and a go/no-go recommendation.

TOOLCHAIN

FauxBank pentest sandbox (https://pentest-fauxbank.vercel.app/), Hacklab (https://alfredang.github.io/ethnicalhacking/), red-team report template

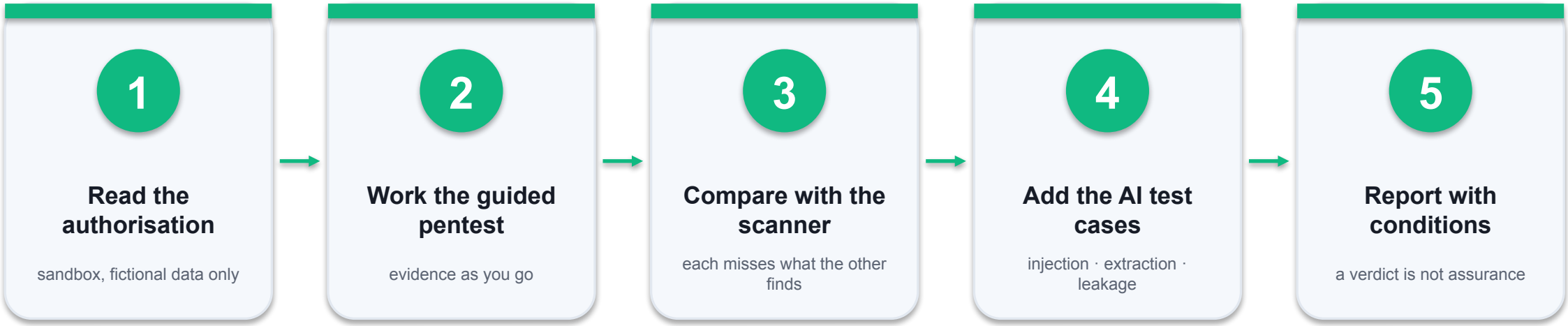
DONE WHEN

Your report contains findings from the sandbox with evidence and OWASP mapping, plus at least five AI-specific test cases the automated scanner could not produce. Your recommendation states conditions, not just a verdict.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10 · PROCESS MAP

How Lab 10 Runs



THE POINT

Develop pre-deployment assurance by red-teaming an AI application for injection, access-control and data-leakage weaknesses, and record the evidence.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10 · VERIFY

Red-Team an AI System Before Deployment

✅ Expected result

Your report contains findings from the sandbox with evidence and OWASP mapping, plus at least five AI-specific test cases the automated scanner could not produce. Your recommendation states conditions, not just a verdict.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 03 · HANDS-ON

Design Deployment Gates and Continuous Monitoring

LAB 11

Develop the deployment gate and the monitoring regime that keep an AI system governed after it goes live.

Most AI governance stops at launch, which is exactly where AI risk begins to change. You will design NovaBank's deployment gate — the evidence required to go live — and the monitoring regime that detects drift, abuse and failure afterwards, with defined thresholds and response actions.

YOU'LL BUILD

A deployment gate checklist with named approvers, plus a monitoring specification with ten metrics, thresholds, alert routing and response actions.

TOOLCHAIN

Deployment gate template, monitoring log extract (agent-monitoring-log.csv), threshold worksheet

DONE WHEN

Every one of your ten metrics has a numeric threshold and a named response action. Using the log extract you can point to at least three anomalies and state which of your alerts would have fired on each.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11 · PROCESS MAP

How Lab 11 Runs

1. **List the gate evidence** — documents, not intentions
2. **Assign approvers** — reuse the Lab 7 RACI
3. **Find the log anomalies** — burst · refusals · injection
4. **Set ten thresholds** — a metric needs a number
5. **Define the response** — who acts, and when to disable

THE POINT

Develop the deployment gate and the monitoring regime that keep an AI system governed after it goes live.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11 · VERIFY

Design Deployment Gates and Continuous Monitoring

✅ Expected result

Every one of your ten metrics has a numeric threshold and a named response action. Using the log extract you can point to at least three anomalies and state which of your alerts would have fired on each.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 03 · HANDS-ON

Run an AI Incident Response Exercise

LAB 12

Apply lifecycle governance under pressure by running an AI security incident from detection through containment, assessment, notification and lessons learned.

A tabletop exercise tests whether your governance survives contact with reality. The trainer will run a prompt-injection incident against NovaAssist in timed injects. You will respond as the governance team, making the decisions your operating model says you own.

YOU'LL BUILD

A completed incident record: timeline, containment decision, personal-data impact assessment, PDPA notification determination and five improvement actions.

TOOLCHAIN

Incident inject pack (incident-injects.md), incident record template, Lab 7 operating model

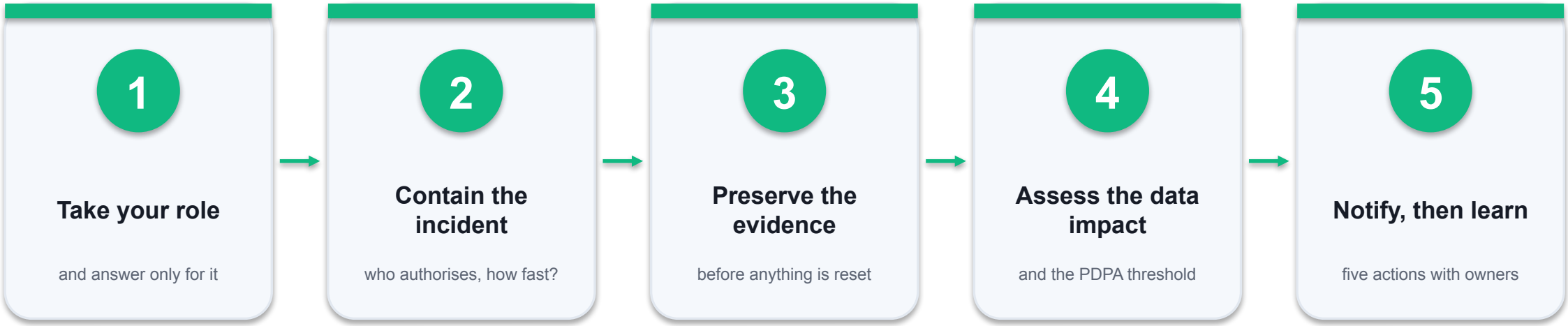
DONE WHEN

Your incident record has a timestamped timeline, a containment decision with a named authoriser, a reasoned PDPA notification determination, and five improvement actions with owners. You can name the single control that would have prevented the incident.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12 · PROCESS MAP

How Lab 12 Runs



THE POINT

Apply lifecycle governance under pressure by running an AI security incident from detection through containment, assessment, notification and lessons learned.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12 · VERIFY

Run an AI Incident Response Exercise

✅ Expected result

Your incident record has a timestamped timeline, a containment decision with a named authoriser, a reasoned PDPA notification determination, and five improvement actions with owners. You can name the single control that would have prevented the incident.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC RECAP

Recap — Governance Controls Across the AI Lifecycle

- You can now: Develop and apply data governance controls for an AI training set, including classification, minimisation, de-identification and retention.
- You can now: Develop pre-deployment assurance by red-teaming an AI application for injection, access-control and data-leakage weaknesses, and record the evidence.
- You can now: Develop the deployment gate and the monitoring regime that keep an AI system governed after it goes live.
- You can now: Apply lifecycle governance under pressure by running an AI security incident from detection through containment, assessment, notification and lessons learned.

© 2026 Tertiary Infotech Academy Pte Ltd

04

TOPIC 04

Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Agentic threat model · identity and least agency · guardrails and sandboxing · CSA agentic RMF profile · risk assessment · roadmap

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

1

What makes an agent different

An agent plans, calls tools, keeps memory and acts — so its risk is set by the tools it can reach, not only by what the model says.

2

The lethal trifecta

Private data access + exposure to untrusted content + the ability to communicate externally. Remove any one leg and mass exfiltration becomes far harder.

3

OWASP Agentic Security Top 10

Goal hijack, tool misuse, identity and authorisation failures, supply chain, code execution, memory poisoning, RAG poisoning, excessive agency, weak isolation and poor operator oversight.

4

Agent identity is not user identity

Each agent needs its own distinct identity, scoped credentials and audit trail so every action is attributable to an accountable owner.

5

Least agency, not just least privilege

Constrain what an agent is allowed to decide, separately from what its credentials permit — the two are different controls.

6

Guardrails at the model boundary

Input and output filtering for PII, jailbreak attempts, prompt injection and unsafe content — a necessary first wave, but never sufficient on its own.

7

Permission ladders and approvals

Tool calls are authorised before execution by policy: deny, ask, or allow. Irreversible actions require a human approval gate.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC WEIGHTING 25%

Key Concepts — Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap (continued)

1

Approval fatigue is a real control failure

If almost every action prompts for approval, approval becomes telemetry rather than control — tune thresholds and measure the edit rate, not just the approval rate.

2

Sandboxing and blast radius

Run agent code with OS-level isolation, restricted network egress and a scoped workspace so a compromised agent cannot reach beyond its task.

3

CSA agentic extensions to the NIST AI RMF

Autonomy-tier classification, delegation accountability and an agent registry (GOVERN); tool-risk and action-consequence analysis (MAP); behavioural telemetry (MEASURE); agentic incident playbooks and decommissioning (MANAGE).

4

Autonomy tiering

Tier 1 supervised, Tier 2 constrained, Tier 3 broad with monitoring, Tier 4 full autonomy — each tier carries escalating oversight obligations.

5

Structured AI risk assessment

Identify the asset and use case, name the threats, rate likelihood and impact, map existing controls, compute residual risk and assign a treatment and owner.

6

Prioritising the roadmap

Sequence by risk reduction per unit of effort: quick wins first (inventory, acceptable use, logging), then structural controls, then assurance and automation.

7

Maturity and metrics

Track inventory coverage, percentage of systems risk-assessed, time to disable an agent, incident count and mean time to respond — governance that is not measured does not persist.

© 2026 Tertiary Infotech Academy Pte Ltd

Why Agents Need Their Own Controls

1

Risk follows the tools

The model's words are not the risk. What the agent can DO — send, write, pay, freeze, delete — is the risk.

2

No human pace limit

An agent repeats an action hundreds of times in the time a person takes to notice one.

3

Memory persists

Poisoned content that enters agent memory keeps influencing behaviour long after the original input.

4

Delegation diffuses accountability

When an agent instructs a sub-agent, who approved that instruction? Usually nobody.

5

Identity is often shared

One service account for the agent means every action is attributable to 'the app', not to an owner.

6

Frameworks lag

The NIST AI RMF treats a read-only recommender and an autonomous executor identically. The CSA profile closes that gap.

© 2026 Tertiary Infotech Academy Pte Ltd

LO4 · SIX LAYERS, NOT ONE FILTER

Defence in Depth for an Agent



PERMISSION IS INFRASTRUCTURE, NOT PROMPT

A rule written in the system prompt is a request. A rule enforced before the tool executes is a control. Only the second survives an injection.

© 2026 Tertiary Infotech Academy Pte Ltd

LO4 · HONEST ABOUT LIMITS

What Each Layer Can and Cannot Do

Layer	Stops	Does NOT stop
Content guardrails	Toxic text, obvious jailbreaks, PII in output	Tool authorisation, credential scope, multi-step exfiltration
Permission ladder	Unauthorised tool calls, dangerous parameters	A permitted tool used for an attacker's purpose
Sandbox	Filesystem and network escape, blast radius	Anything the agent is legitimately allowed to reach
Human approval	Irreversible action taken silently	Anything below the approval threshold; fatigue-driven rubber-stamping
Audit trail	Nothing — it is detective, not preventive	Any attack; it tells you what happened afterwards
Architecture (break the trifecta)	Whole classes of exfiltration	Threats inside the remaining capability set

WHEN IT MATTERS No single layer is sufficient. The architectural choice — not combining private data, untrusted content and an outbound channel in one agent — does more than all the filters put together.

© 2026 Tertiary Infotech Academy Pte Ltd

The CSA Agentic Extensions to the NIST AI RMF

1

AG-GV.1 Autonomy tier classification

Four tiers with escalating oversight, because a recommender and an executor are not the same risk.

2

AG-GV.2 Delegation accountability

Document oversight boundaries, escalation triggers and the lineage from an action back to a named human.

3

AG-GV.3 Agent lifecycle registry

A live inventory of agent authorities, tool access, delegation relationships and review schedule.

4

AG-MP.1 / MP.2 Tool and consequence analysis

Classify tools by consequence and reversibility; map which tool sequences lead to which real-world outcomes.

5

AG-MS.1 Behavioural telemetry

Action velocity, permission escalation rate, cross-boundary calls, delegation depth, exception rate.

6

AG-MG.1 / MG.3 Incident and decommissioning

Playbooks for agent compromise, hijack, runaway and delegation-chain compromise; structured retirement.

© 2026 Tertiary Infotech Academy Pte Ltd

LO4 · AG-GV.1

Autonomy Tiering — Tier by Capability, Not by Title

1

Tier 1 · Supervised

Proposes only; a human acts. Lightest oversight — but confirm it truly cannot act.

2

Tier 2 · Constrained

Acts within a fixed allowlist of reversible actions. Periodic review of the allowlist.

3

Tier 3 · Broad with monitoring

Wide capability with runtime telemetry and thresholds. Continuous monitoring is mandatory, not optional.

4

Tier 4 · Full autonomy

Highest obligation: pre-authorised containment, tested kill switch, named standing authority to disable.

5

The common error

Tiering by how the agent is described. 'Just a helpdesk assistant' that resets passwords is not Tier 1.

6

Tier drives obligation

If the oversight requirement does not rise with the tier, the tiering is decorative.

© 2026 Tertiary Infotech Academy Pte Ltd

Approval Fatigue — When a Control Stops Being One

1

The failure

When almost every action prompts for approval, approvers stop reading and start clicking.

2

It gets worse with time

Approval discipline decays as session count rises — the pattern is well documented across agent deployments.

3

Measure the edit rate

Not the approval rate. How often does the human actually change or reject the proposed action?

4

Auto-allow the routine

Reserve the gate for irreversible and outbound actions; let low-consequence reads through.

5

Watch for denial clusters

Three consecutive denials, or twenty in a session, should escalate to a human review of the agent itself.

6

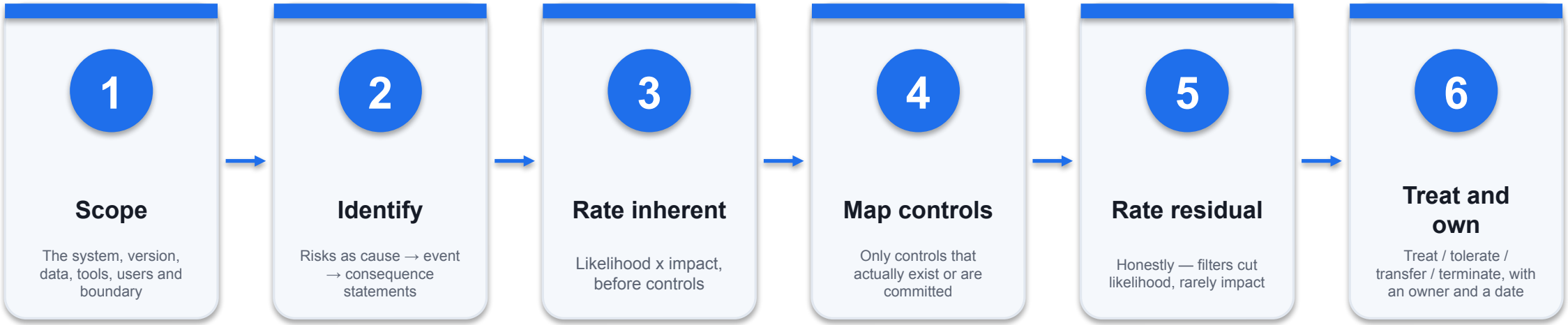
Design the volume deliberately

State the number of approvals per day above which your gate stops being a control.

© 2026 Tertiary Infotech Academy Pte Ltd

LO4 · THE DOCUMENT A REGULATOR WILL ASK FOR

Structured AI Risk Assessment

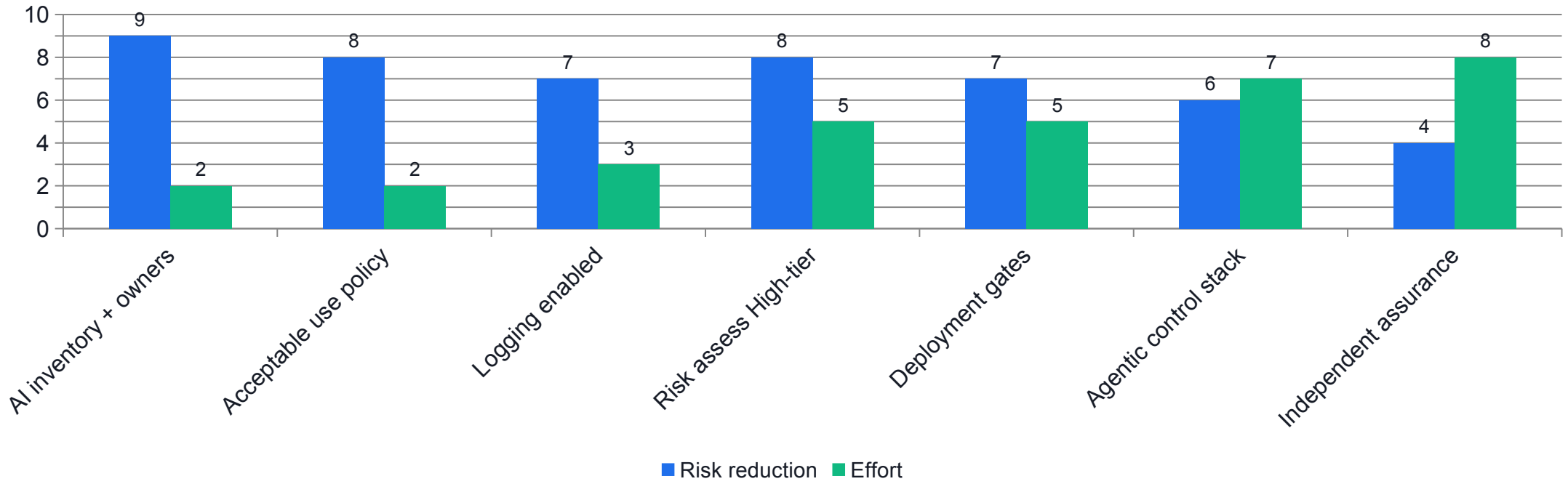


THE MOST COMMON DEFECT

Risks written as single words. 'Prompt injection' is a cause. A risk statement names the cause, the event and the business consequence.

© 2026 Tertiary Infotech Academy Pte Ltd

Sequencing the Roadmap by Risk Reduction per Unit of Effort



WHAT THE DATA SHOWS

The first three initiatives are low effort and high risk reduction — do them first. Independent assurance matters, but it cannot precede having something to assure. Relative teaching values, not effort estimates for your organisation.

© 2026 Tertiary Infotech Academy Pte Ltd

Metrics That Keep a Programme Alive

1

Inventory coverage

Percentage of known AI systems registered with a named owner. Your foundational metric.

2

Assessment coverage

Percentage of High-risk systems with a current risk assessment.

3

Policy attestation

Percentage of staff who have attested to the acceptable-use policy.

4

Time to disable

Minutes to disable a live agent — tested, not estimated.

5

Incidents and MTTR

Count of AI incidents and mean time to respond.

6

Report them upward

Governance that is not measured and reported does not survive the next budget cycle.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Labs 13–14

- Design the Agentic Security Control Stack
- Apply the CSA Agentic Extensions to the NIST AI RMF

Labs 15–16

- Conduct a Full AI Security Risk Assessment
- Capstone — Build the AI Security Governance Roadmap

—

- —

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 04 · HANDS-ON

Design the Agentic Security Control Stack

LAB 13

Implement layered security controls for an agentic AI system: identity, guardrails, permission ladders, sandboxing and human approval gates.

You will redesign NovaAssist with a real defence-in-depth stack. Working from the OWASP Agentic Security Top 10, you will specify each control layer, decide which tool calls need approval, and write the permission policy that governs the agent before it acts.

YOU'LL BUILD

A layered agentic control specification: agent identity and scopes, guardrail rules, a deny/ask/allow permission policy for 12 tools, sandbox boundaries and human approval gates.

TOOLCHAIN

NovaAssist tool catalogue (agent-tool-catalogue.csv), OWASP ASI Top 10 reference, control stack template

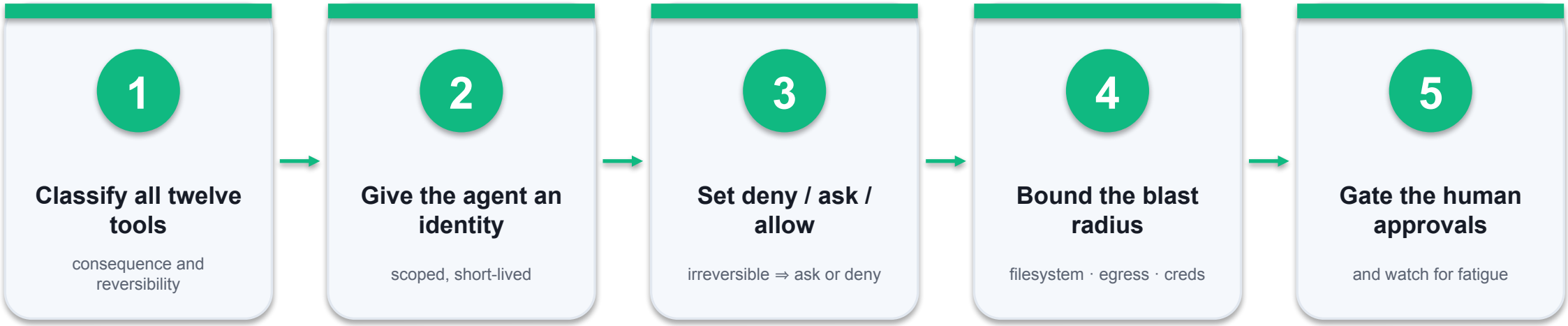
DONE WHEN

Every irreversible and external-communication tool is set to ask or deny. Your three deny rules are specific enough to be implemented, and you can name at least two attack paths your stack does not stop.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13 · PROCESS MAP

How Lab 13 Runs



THE POINT

Implement layered security controls for an agentic AI system: identity, guardrails, permission ladders, sandboxing and human approval gates.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13 · VERIFY

Design the Agentic Security Control Stack

✅ Expected result

Every irreversible and external-communication tool is set to ask or deny. Your three deny rules are specific enough to be implemented, and you can name at least two attack paths your stack does not stop.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 04 · HANDS-ON

Apply the CSA Agentic Extensions to the NIST AI RMF

LAB 14

Implement agentic-specific governance by applying autonomy tiering, delegation accountability, an agent registry and behavioural telemetry.

The NIST AI RMF treats a read-only recommender and an autonomous executor identically. The CSA agentic profile closes that gap. You will apply its extensions to NovaBank's agent estate: tier every agent, document delegation accountability, build the agent registry and define behavioural telemetry.

YOU'LL BUILD

An agentic governance pack: five agents tiered with justification, a delegation accountability record, a completed agent registry and a behavioural telemetry specification.

TOOLCHAIN

Agent estate pack (novabank-agents.md), CSA agentic RMF profile reference, registry template

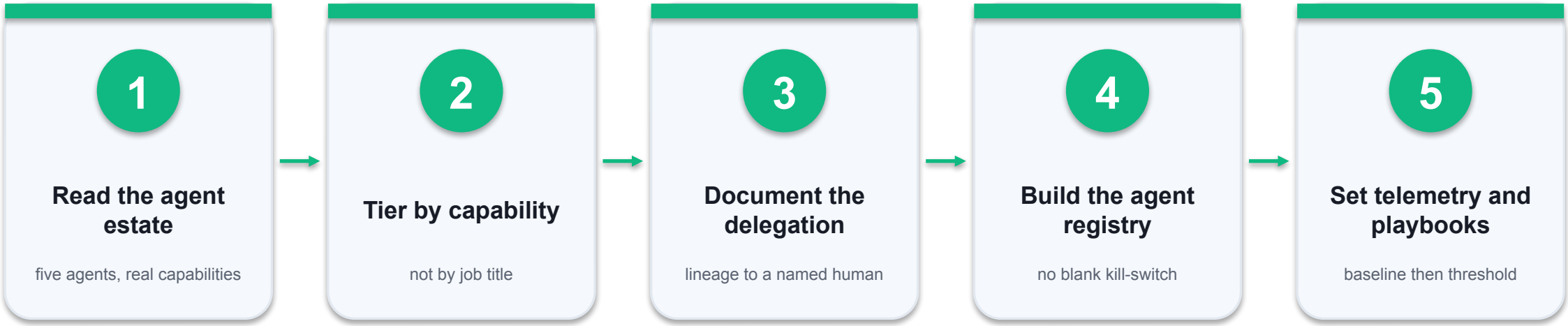
DONE WHEN

All five agents are tiered with a justification drawn from their capabilities, your registry has no blank kill-switch field, and your telemetry metrics each have a baseline and a threshold. You can explain why tiering by capability beats tiering by job title.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14 · PROCESS MAP

How Lab 14 Runs



THE POINT

Implement agentic-specific governance by applying autonomy tiering, delegation accountability, an agent registry and behavioural telemetry.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14 · VERIFY

Apply the CSA Agentic Extensions to the NIST AI RMF

✅ Expected result

All five agents are tiered with a justification drawn from their capabilities, your registry has no blank kill-switch field, and your telemetry metrics each have a baseline and a threshold. You can explain why tiering by capability beats tiering by job title.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 04 · HANDS-ON

Conduct a Full AI Security Risk Assessment

LAB 15

Implement a structured AI risk assessment producing rated risks, mapped controls, residual risk and assigned treatments with owners.

This is the assessment that a regulator, an auditor or a board will ask to see. You will run a complete structured risk assessment on NovaAssist, combining everything from the previous fourteen labs into a single defensible document with rated, owned and treated risks.

YOU'LL BUILD

A complete AI security risk assessment: 12 rated risks with likelihood, impact, existing controls, residual rating, treatment decision, owner and target date.

TOOLCHAIN

Risk assessment template (risk-assessment-template.csv), 5x5 rating matrix, all prior lab outputs

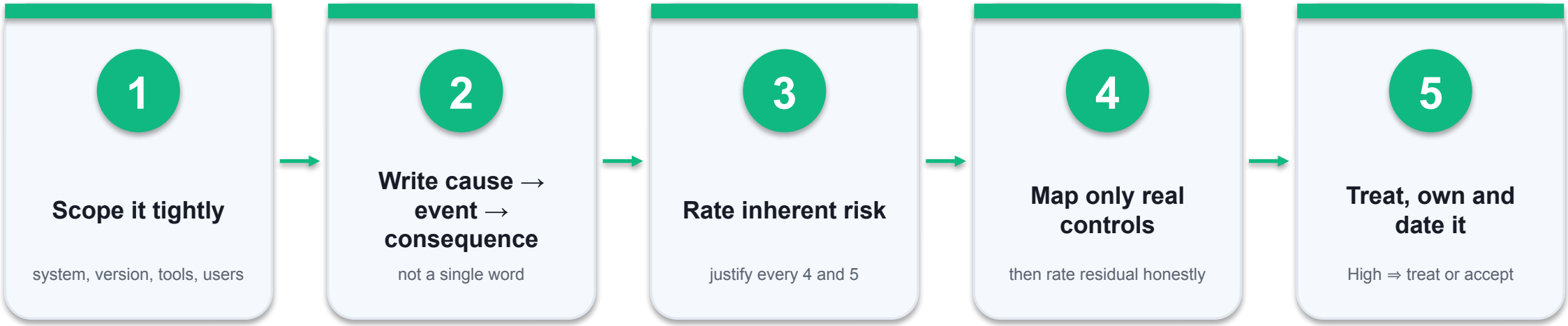
DONE WHEN

All twelve risks are written as cause-event-consequence statements, every residual High risk has either a treatment plan or a recorded acceptance by a named executive, and every treatment has an owner who exists in your operating model.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15 · PROCESS MAP

How Lab 15 Runs



THE POINT

Implement a structured AI risk assessment producing rated risks, mapped controls, residual risk and assigned treatments with owners.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15 · VERIFY

Conduct a Full AI Security Risk Assessment

✅ Expected result

All twelve risks are written as cause-event-consequence statements, every residual High risk has either a treatment plan or a recorded acceptance by a named executive, and every treatment has an owner who exists in your operating model.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 04 · HANDS-ON

Capstone — Build the AI Security Governance Roadmap

LAB 16

Implement a prioritised, costed and sequenced AI security governance implementation roadmap and present it for executive approval.

The capstone brings the whole course together. You will consolidate every artefact you have produced into a 12-month AI security governance implementation roadmap for NovaBank, sequenced by risk reduction per unit of effort, with metrics that prove the programme is working — then present it for approval.

YOU'LL BUILD

A 12-month AI security governance roadmap across three phases with initiatives, owners, effort, dependencies and success metrics, plus a five-slide executive presentation.

TOOLCHAIN

Roadmap template, maturity model, all prior lab outputs, presentation template

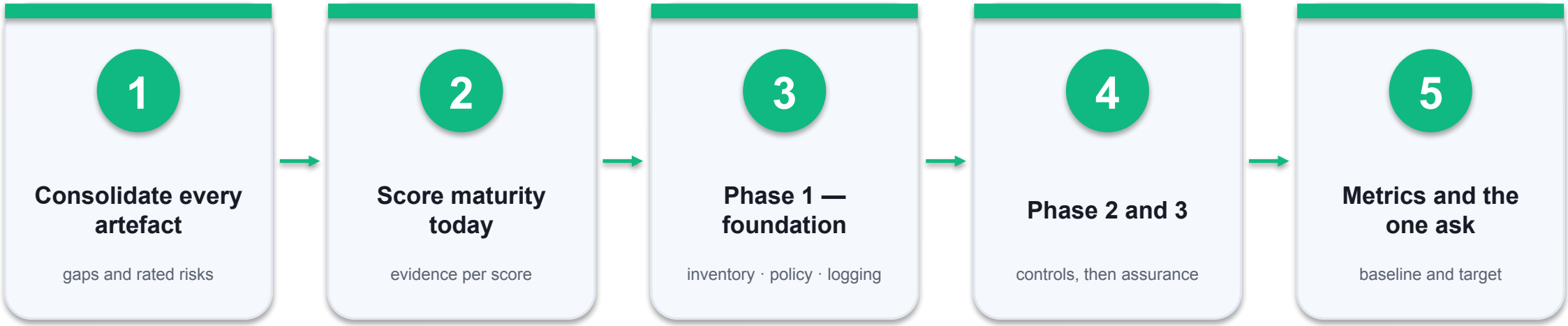
DONE WHEN

Every initiative in your roadmap traces back to a specific gap or a specific rated risk, the phases respect their dependencies, and all six metrics have a baseline and a target. Your five-slide deck makes the ask explicit on the final slide.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16 · PROCESS MAP

How Lab 16 Runs



THE POINT

Implement a prioritised, costed and sequenced AI security governance implementation roadmap and present it for executive approval.

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16 · VERIFY

Capstone — Build the AI Security Governance Roadmap

✅ Expected result

Every initiative in your roadmap traces back to a specific gap or a specific rated risk, the phases respect their dependencies, and all six metrics have a baseline and a target. Your five-slide deck makes the ask explicit on the final slide.

IF IT DOESN'T WORK

Nothing happens

Check the .env file is in the labs folder and the key has no quotes or spaces.

Auth or 401 error

Re-copy the API key from AI Studio; confirm GOOGLE_GENAI_USE_VERTEXAI=0.

ModuleNotFoundError

Run uv sync again, and prefix commands with uv run so the venv is used.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC RECAP

Recap — Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

- You can now: Implement layered security controls for an agentic AI system: identity, guardrails, permission ladders, sandboxing and human approval gates.
- You can now: Implement agentic-specific governance by applying autonomy tiering, delegation accountability, an agent registry and behavioural telemetry.
- You can now: Implement a structured AI risk assessment producing rated risks, mapped controls, residual risk and assigned treatments with owners.
- You can now: Implement a prioritised, costed and sequenced AI security governance implementation roadmap and present it for executive approval.

© 2026 Tertiary Infotech Academy Pte Ltd

WRAP-UP

Course Summary & Next Steps

© 2026 Tertiary Infotech Academy Pte Ltd

LEARNING OUTCOMES

What You Achieved

1

LO1 · Analysed foundations and risks

You inventoried an AI estate including shadow AI, mapped traditional threats to their AI-era variants, analysed a live agent design against the lethal trifecta and the NIST GenAI risks, and built a costed business case.

2

LO2 · Evaluated frameworks, built the structure

You ran a NIST AI RMF gap assessment on real evidence, drafted an enforceable policy set mapped to Singapore's MGF, designed a governance operating model with a single-A RACI, and applied the PDPA and PDPC AI guidelines to four scenarios.

3

LO3 · Developed lifecycle controls

You governed a training dataset end to end, red-teamed a system before deployment, designed deployment gates and a monitoring regime with thresholds, and ran an AI incident from detection to notification.

4

LO4 · Implemented agentic controls and a roadmap

You designed a five-layer agentic control stack, applied the CSA agentic extensions, completed a twelve-risk assessment, and produced a 12-month roadmap with metrics.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU CAN REUSE

The Artefacts You Are Taking Away

1

AI system inventory

A template and a worked example you can populate for your own organisation on Monday.

2

Policy set

An acceptable-use policy and a risk-management standard, mapped to MGF dimensions and RMF subcategories.

3

Operating model and RACI

A committee terms of reference and a twelve-control RACI that passes the single-A rule.

4

Risk assessment

A twelve-risk assessment with a 5x5 matrix, residual ratings, treatments and owners.

5

Agentic control stack

A layered specification with a deny/ask/allow tool policy and an agent registry.

6

12-month roadmap

Three phases, sequenced by dependency, with six measurable programme metrics.

© 2026 Tertiary Infotech Academy Pte Ltd

MAKE IT REAL

Your First 30 Days Back at Work

1

Week 1 · Find out what you run

Start the inventory. Expense claims, SaaS admin consoles and an honest staff survey will find more than IT records will.

2

Week 1 · Name owners

Every AI system gets a named accountable human. Systems with no owner are your first finding.

3

Week 2 · Issue interim guidance

One page: what staff may and may not put into AI tools, and the route to ask. Do not wait for the full policy set.

4

Week 3 · Turn on logging

You cannot investigate what you did not record. Logging is cheap and it is the precondition for everything else.

5

Week 4 · Assess your highest-risk system

One proper risk assessment beats a portfolio-wide survey. Use the Lab 15 template.

6

Then · Take it to the board

Use your Lab 4 business case and Lab 16 roadmap. Ask for one thing.

© 2026 Tertiary Infotech Academy Pte Ltd

NEXT STEPS

Continue Your Learning

1

NIST AI RMF

nist.gov/itl/ai-risk-management-framework — the framework, the Playbook and the GenAI profile (AI 600-1).

2

AI Verify Foundation

aiverifyfoundation.sg — the Model AI Governance Framework for GenAI and the testing toolkit.

3

PDPC

pdpc.gov.sg — the Advisory Guidelines on the Use of Personal Data in AI Recommendation and Decision Systems.

4

OWASP

The Agentic Security Initiative Top 10 — the threat taxonomy for agents.

5

Cloud Security Alliance

The Agentic AI NIST RMF Profile — AG-GV, AG-MP, AG-MS and AG-MG control extensions.

6

Practise the labs again

Re-run the labs against your own organisation's real AI estate — that is where the value is realised.

© 2026 Tertiary Infotech Academy Pte Ltd

CONTINUE WITH TERTIARY INFOTECH

Recommended Courses

1. **WSQ - Developing Ethical Strategies for Responsible Generative AI**
2. **WSQ - Cybersecurity Risk Management for Businesses**
3. **WSQ - Data Protection and Privacy Management (PDPA)**
4. **WSQ - Applied Generative AI for Business Productivity**

© 2026 Tertiary Infotech Academy Pte Ltd

WE'RE HERE TO HELP

Support

- If you have any enquiries during or after the class, you can contact us below.
- Email: enquiry@tertiaryinfotech.com
- Tel: +65 6100 0613
- Website: www.tertiarycourses.com.sg
- LMS / TMS: https://lms-tms.tertiaryinfotech.com

© 2026 Tertiary Infotech Academy Pte Ltd

WRAP-UP

Assessment

1

Written Assessment (SAQ)

1 hour · open book · short-answer knowledge questions on AI security governance.

2

Case Study (CS)

1 hour · open book · one coherent governance case study drawn from the labs.

3

Digital attendance

Remember to take the Assessment digital attendance (TRAQOM) before you start.

4

Submit on the LMS

Upload your completed answers at https://lms-tms.tertiaryinfotech.com/

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1

TRAQOM survey

Scan the QR on the LMS

2

Digital attendance

Scan the SSG QR

3

Sit the WA then the CS

Open book · 1 hour each

4

Submit on the LMS

Upload your answers

5

Sign the record

Assessment Summary Record

REMEMBER

All five steps are mandatory for WSQ funding — missing the digital attendance or the TRAQOM survey can invalidate your claim.

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

1

Three times a day

Take the AM, PM and Assessment digital attendance — mandatory for every WSQ-funded course.

2

Trainer shows the QR

The trainer or administrator displays the digital attendance QR code from the SSG portal.

3

Scan and submit

Scan the QR code with your mobile phone camera and submit your attendance.

4

75% minimum

A minimum of 75% attendance is required to be eligible for assessment and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

GOVERN WELL

Thank You!

You can now analyse AI business risk, build a governance framework, apply controls across the AI lifecycle, secure agentic AI and deliver an implementation roadmap.

© 2026 Tertiary Infotech Academy Pte Ltd